CYPHER GROUP INC. · SIMULATED CASE STUDY

CGI-ISO-001 — ISO/IEC 27001:2022 Readiness Assessment & Statement of Applicability

Cypher Group Inc. · Version 1.0 · 16 September 2026

> **CASE STUDY NOTICE.** Cypher Group Inc. is a simulated company. Every organisation, person, system, finding, score, date, cost and figure in this document was created to demonstrate applied GRC methodology. This is a portfolio artifact, not evidence of employment or of a real engagement. ISO/IEC 27001 requirement wording is paraphrased; obtain the standard from ISO or a national body.

Field	Value
Document ID	CGI-ISO-001
Title	ISO/IEC 27001:2022 Readiness Assessment and Statement of Applicability
Version	1.0
Status	Draft for approval (the SoA becomes v1.0 when the CEO approves it, action ISO-06)
Assessment date	16 September 2026
Prepared by (Assessor)	O.S
Approving authority	Jerry Gold, Chief Executive Officer
Standard	ISO/IEC 27001:2022 including Amendment 1:2024; control guidance ISO/IEC 27002:2022
Inputs consumed	CGI-POL-001 to -005 v1.0 · CGI-TRK-001 · EXC-001 to -003 · CGI-RSK-001 v1.1 (R-001 to R-005, VR-001 to VR-009) · CGI-GAP-001 v1.0 (scores as updated by Project 4) · CGI-TPR-001 v1.0 and CGI-TPR-002
Next review	SoA: 30 September 2027, or on material change

Headline result: 88 of 93 Annex A controls are applicable and 5 are excluded. 0 are Implemented to an auditable standard, 45 are Partial and 43 are Not started. Certification readiness is 30.6%. A Stage 1 audit today is a NO-GO, with 8 of 8 gate requirements failing. The realistic certification date is November 2027.

Contents

- **Part 1** — The Why: ISO/IEC 27001 in plain English
- **Part 2** — Scope statement and ISMS boundary
- **Part 3** — Statement of Applicability: all 93 controls
- **Part 4** — Clauses 4–10 readiness assessment
- **Part 5** — Mandatory documented information checklist
- **Part 6** — Certification readiness score and go/no-go
- **Part 7** — Prioritised roadmap to certification
- **Part 8** — One-page executive summary
- **Part 9** — Effect on the CGI-GAP-001 maturity score
- **Appendix A** — Verification, assumptions and limitations
- **Appendix B** — Glossary

Files in this deliverable

File	What it is
`05-iso27001-readiness-and-soa.md`	This document.
`05-iso27001-readiness-and-soa.pdf`	The same document, formatted for reading or printing.

File	What it is
`05-iso27001-readiness-and-soa.xlsx`	The working workbook: the SoA with status derived by formula, the readiness score with its gate override, the costed roadmap and 18 consistency checks.
`05-iso27001-readiness-and-soa.csv`	The full 93-row SoA: the 12 mandated columns plus 5 governance columns (also the Notion import).
`data/05-clause-readiness.csv`	Clauses 4–10 readiness: 28 requirements with Stage 1 gate flags.
`data/05-documented-information-checklist.csv`	The 27 items of mandatory documented information.
`data/05-certification-roadmap.csv`	ISO-01 to ISO-17 with owners, dates, phases and costs.
`data/05-rec-reconciliation.csv`	CGI-GAP-001 REC-01 to REC-18 reconciled against the certification plan.
`data/05-gap-mapping-reconciliation.csv`	Control by control: what CGI-GAP-001 mapped, and what it missed.
`../templates/iso27001-*-template.*`	Blank `[BRACKETED]` SoA (Markdown, CSV, Excel) and clauses 4–10 readiness assessment (Markdown, CSV, Word).

Part 1 — The Why

1.1 What ISO/IEC 27001:2022 is

ISO (International Organization for Standardization) and **IEC** (International Electrotechnical Commission) publish information security standards jointly. **ISO/IEC 27001:2022** was published in October 2022 and amended in 2024 (**Amd 1**) to require organisations to consider whether climate change is a relevant issue (clauses 4.1 and 4.2). The transition deadline for 2013-edition certificates was 31 October 2025.

It is a **requirements standard**. Every "shall" in it can be audited, which is why an organisation can be **certified** against it.

	NIST CSF 2.0 (used in CGI-GAP-001)	ISO/IEC 27001:2022 (this document)
Type	Voluntary framework of outcomes	Requirements standard ("shall")
Certifiable	No	Yes, by an accredited certification body
Question it answers	How good is our security, outcome by outcome?	Do we run a management system that keeps choosing, operating and improving controls based on risk?
Structure	6 Functions, 22 Categories, 106 Subcategories	Mandatory clauses 4–10, plus Annex A (93 reference controls)
Scoring	None built in (CGI-GAP-001 supplies a 0–4 scale)	Conformity or nonconformity, requirement by requirement

In one line: CSF measures how good your security is. ISO 27001 certifies that you run a system that manages it.

1.2 The ISMS, the clauses, and why Annex A is not the standard

An **ISMS** (Information Security Management System) is not software. It is the whole machine that makes an organisation **Plan → Do → Check → Act** (PDCA) on security: policies, roles, the risk process, records, audits and reviews.

- **Clauses 4–10 are the standard.** They set out context, leadership, planning, support, operation, performance evaluation and improvement. **None of them can be excluded.**
- **Annex A is a reference list of 93 controls.** Clause 6.1.3 c) uses it as an *omission check*: you compare the controls your risk treatment needs against Annex A so that nothing necessary was missed. **A control can be excluded, with justification.**
- People mistake Annex A for the standard because it is the concrete, technical-looking part, because ISO/IEC 27002 is a whole book about it, and because the SoA is laid out in Annex A order. Organisations that make this mistake implement controls and then fail on clause 9.2 (internal audit) or 9.3 (management review).

1.3 The Statement of Applicability

Clause 6.1.3 d) requires one document that lists **the necessary controls, why each is included, whether each is implemented, and why any Annex A control is excluded.** It is the single most important ISMS document because it is the only one that joins **risk → treatment decision → control → implementation status → evidence**. An auditor opens it first because it is the organisation's list of claims: the audit plan and evidence samples are built from it, and any contradiction between it and the risk register shows up immediately. Certificates commonly cite the SoA version they were issued against.

"Applicable but not implemented" is legitimate. *Applicable* answers "do our risks need this?". *Status* answers "is it running yet?". The standard asks whether each control is implemented, so it expects some answers to be "not yet". The condition is that the risk treatment plan dates the control and the risk owners have accepted the residual risk in the meantime (6.1.3 e–f). **The real failure is marking a control "not applicable" to hide a gap your own risk register needs closed.**

1.4 How certification works

Term	Meaning
Stage 1	Readiness and documentation review: scope, SoA, risk method, ISMS policy, evidence that an internal audit and a management review have already taken place. Decides whether Stage 2 can proceed.
Stage 2	Implementation and effectiveness audit: interviews, evidence sampling, tracing risk → SoA → evidence.
Major nonconformity	A requirement absent or totally broken down, or significant doubt that the ISMS achieves its results (for example, no internal audit ever held). No certificate until the certification body verifies the correction and corrective action. Under ISO/IEC 17021-1, if this cannot be verified within six months of the end of Stage 2, Stage 2 is repeated.
Minor nonconformity	An isolated lapse that does not undermine the requirement (for example, one leaver removed in 9 hours against a 4-hour SLA). A correction and root-cause corrective action plan is accepted, the certificate can be issued, and the fix is verified at the next surveillance audit.
Certification cycle	Three years, with surveillance audits in years 1 and 2 and a recertification audit before expiry.
Accreditation body (AB)	Checks the checkers: DAkkS (Germany), UKAS (UK), ANAB (US). It assesses certification bodies against ISO/IEC 17021-1 and ISO/IEC 27006-1. The IAF (International Accreditation Forum) links ABs, and IAF CertSearch lets anyone verify a certificate.
Certification body (CB)	The firm that audits the organisation and issues the certificate. ISO itself certifies nobody.
Scope statement	The words on the certificate saying what is covered. A certificate can be technically valid and commercially useless if its scope does not cover the service the customer is buying (Part 2.4).

1.5 The 93 controls, 4 themes and 5 attributes

Theme	Clause	Controls
Organizational	A.5	37
People	A.6	8
Physical	A.7	14
Technological	A.8	34
Total		**93** (2013 had 114; the 2022 revision created 11 new controls, merged 24 and updated 58)

ISO/IEC 27002:2022 tags every control with five **attributes**:

- **Control type:** Preventive, Detective, Corrective
- **Information security properties:** Confidentiality, Integrity, Availability
- **Cybersecurity concepts:** Identify, Protect, Detect, Respond, Recover (the CSF 1.1 functions)
- **Operational capabilities:** 15 values, for example Secure_configuration and Supplier_relationships_security

- **Security domains:** Governance_and_Ecosystem, Protection, Defence, Resilience

1.6 Two mechanisms used on every SoA row

- **Brakes or seatbelt.** A control acting *before* the bad event reduces **likelihood** (A.8.5 MFA, A.8.8 patching, A.8.28 secure coding). A control acting *after* it reduces **impact** (A.8.13 backup, A.8.24 encryption of a stolen copy, A.5.26 incident response). When a control was *prepared* is irrelevant; what matters is when it *acts*.
- **Weakest relevant domain.** A risk's residual score is driven by the weakest control domain **relevant to that risk**. R-004 is a flaw in Cypher Group Inc.'s own code, so it is driven by PR.PS (0). GV.SC rising to 2 changes nothing for R-004.

Part 2 — Scope statement and ISMS boundary

2.1 The certificate wording

> **Scope of certification.** The information security management system supporting the development, operation, hosting and support of the Cypher Group Inc. cloud-based project-management software-as-a-service platform provided to business customers, including the people, processes and technology at its head office [address per assumption ISO-A01] and in its third-party cloud hosting environment, in accordance with the Statement of Applicability version 1.0.

Why each phrase is there:

- **"development, operation, hosting and support"** covers the whole service life cycle a customer depends on: code (R-004), cloud (R-005), support staff (VR-003 through SupportCo) and hosting (VR-002).
- **"project-management software-as-a-service platform provided to business customers"** names the product a buyer's procurement team is actually buying.
- **"people, processes and technology"** means no part of the company can later be argued out of scope.
- **"third-party cloud hosting environment"** makes the interface with CloudCo explicit (clause 4.3 c) without claiming CloudCo's own controls.
- **"Statement of Applicability version 1.0"** binds the certificate to the approved SoA.

2.2 ISMS boundary

Dimension	In scope	Out of scope, and why
Organisation	All 50 employees and all six functions (leadership, engineering, IT operations, customer success, people and operations, finance)	Nothing. At 50 people every function touches customer or platform data: Customer Success through SupportCo, CRMCo and ScribeCo; Finance through PaymentsCo; People through HRCo.
Locations	Head office (single site, ISO-A01); remote and home working under CGI-POL-001 section 4.4	No data centre is operated. Physical controls for production are CloudCo's and are assured through A.5.23 (VRA-2026-001).
Technology	CloudCo production accounts (eu-central-1; backups in us-east-1); CodeCo; OfficeCo (identity provider); ChatCo; LoginCo; MonitorCo; PaymentsCo integration; BYOD endpoints as far as they access company data	The internal controls of the 17 vendors. They are managed as **interfaces** through A.5.19 to A.5.23 and CGI-TPR-001, not audited as part of this ISMS.
Information	Customer account data and project content (~200 customers), payment metadata, internal documents, employee data, limited personal data (CGI-POL-004 tiers)	Cardholder numbers: none are held (CGI-POL-004 section 4.1.4, AVD-001); PaymentsCo processes them.
Processes	Everything in CGI-POL-001 to -005, CGI-RSK-001, CGI-TPR-001 and this document	None.
Interfaces and dependencies (clause 4.3 c)	17 vendors (CGI-VEN-001 to -017), tiered 7 / 6 / 4; the CloudCo shared-responsibility boundary (to be documented in ISO-02)	-

2.3 Why the whole company, not a slice

A narrower scope ("engineering only") would save perhaps a day of audit time. It would also exclude the customer-facing staff who hold customer data in three Tier 2 tools, and the finance function that owns the PaymentsCo relationship. **The saving is not worth a certificate that answers the wrong question.**

2.4 How a badly written scope gets rejected commercially while still valid

A certification body can legitimately certify a narrow scope, and the certificate will be accredited and real. The customer's procurement team then compares **the scope wording** against **the service being bought** (this is question VQ-11 in Cypher Group Inc.'s own vendor questionnaire). Common failures:

Bad scope	Why it is valid	Why a buyer rejects it
"The ISMS of the IT department of Cypher Group Inc."	A CB can certify a department	The buyer's data sits in the platform, run by engineering and customer success
"Information security at Cypher Group Inc."	It names an organisation	It names no service, location or environment, so nothing can be relied on
"Corporate systems at the head office"	Certifiable	Excludes the cloud environment where every customer record lives
A scope that differs from the website and the SoA	Each document is fine on its own	The inconsistency itself is the finding

Part 3 — Statement of Applicability

3.1 How this SoA was built (build narration)

1. **Started from the CGI-GAP-001 mappings.** The 22 Category rows in CGI-GAP-001 map **55 distinct Annex A controls**. Every one of them was carried into this SoA, and its row keeps the Category that mapped it.
2. **Listed the 38 controls CGI-GAP-001 never mapped**, and decided each one on its merits (section 3.4).
3. **Traced every applicable control** to at least one of: a CGI-RSK-001 v1.1 risk ID, a CGI-GAP-001 Category score, or a CGI-TPR-001 finding. Where none applied, the row says so and is marked *Contractual / stakeholder* or *Legal*. **No risk was invented to justify a control**; three candidate risks are proposed for the next register review instead (section 3.7).
4. **Scored each control's maturity 0–4** on the CGI-GAP-001 section 3.1 scale, with one consistency rule: **a control may not score higher than the highest current score of the Categories it traces to.**
5. **Derived the status from the maturity** (a formula in the workbook, not typed): 0 = Not started; 1–2 = Partial; 3–4 = Implemented. **An approved but unevidenced control is a 2, so it can never be Implemented.**
6. **Applied the fragment rule** from CGI-GAP-001 section 3.1: a clause that touches a control's object is recorded in the evidence column, but it does not change the status when it covers a different asset class, or states a requirement without the rules the control needs. For example, the endpoint patch rule is recorded under A.8.8 but does not lift the platform control, and the CGI-POL-004 Handling Matrix says *where* to encrypt but not *how*, so A.8.24 stays Not started.
7. **Credited the policy pack's own mappings.** CGI-POL-001 to -005 map 38 Annex A controls in their framework tables. Each of those rows either credits the clause or names it as a fragment. That is why A.7.7 (clear desk and clear screen) is Partial: CGI-POL-001 sections 4.4.2, 4.8.2 and 4.9.3 already set the rule, so "Held: none" would have been false.
8. **Reconciled** against PR.PS = 0 (section 3.6), GV.SC = 2 (section 3.5) and REC-01 to REC-18 (Part 7), and verified all counts in code (Appendix A).

3.2 Summary

Theme	Controls	Applicable	Excluded	Implemented	Partial	Not started
Organizational	37	37	0	0	31	6
People	8	8	0	0	5	3
Physical	14	10	4	0	3	7
Technological	34	33	1	0	6	27
Total	**93**	**88**	**5**	**0**	**45**	**43**

Excluded (5): A.7.4, A.7.6, A.7.11, A.7.12, A.8.30.

Zero controls are Implemented. That is the honest reading, not a harsh one. The only control-like activity at Cypher Group Inc. with operating evidence is the risk assessment itself (ID.RA = 3). That satisfies **clause 8.2**, not an Annex A control, and ID.RA's own Annex A mappings (A.5.7, A.8.8) are both Not started.

Basis for inclusion (88 applicable controls):

- **75 are risk-based**: traced to a CGI-RSK-001 v1.1 risk ID, and in most cases also to a Category score and a vendor finding.
- **3 are traced only to a CGI-GAP-001 Category** (A.5.6, A.7.9, A.7.14).
- **10 are included for contractual, stakeholder or legal reasons, NOT risk-based:** A.5.32, A.7.1, A.7.2, A.7.3, A.7.5, A.7.7, A.7.8, A.7.13, A.8.6, A.8.34.

3.3 Exclusions and why each is defensible

Control	Why excluded	What would bring it back
A.7.4 Physical security monitoring	No secure areas or on-site processing; production physical monitoring is CloudCo's, assured through A.5.23	Servers, network equipment or Confidential paper kept on site
A.7.6 Working in secure areas	No secure area is defined	A server or network room
A.7.11 Supporting utilities	No information processing facility is operated	As above
A.7.12 Cabling security	No on-premises cabling carries production data	As above
A.8.30 Outsourced development	All code is written by employees (ISO-A02)	Any contractor or agency writing code

Every exclusion rests on a fact (ISO-A02, ISO-A03) that an auditor can test, and each names the change that would reverse it. **An exclusion that cannot say what would reverse it is not a justification, it is a preference.**

3.4 Reconciliation against the CGI-GAP-001 Annex A mappings

- **CGI-GAP-001 mapped 55 of 93 controls. It missed 38.** Of those, **33 are applicable** and 5 are among the five exclusions (A.7.4, A.7.6, A.7.11, A.7.12, A.8.30).
- **The most important omission is A.8.3 (information access restriction).** R-004 is a production API *authorisation* flaw, and A.8.3 is the Annex A control for exactly that. The category-level mapping listed the development-process controls but not the control the flaw itself breaks.
- **A.5.34 (privacy and protection of PII) was also missed**, although Cypher Group Inc. is a GDPR processor for ~200 customers and CGI-TPR-001 found 6 vendors with no DPA.

Control	Title	Applicable	Why CGI-GAP-001 missed it	Now traced to
A.5.8	Information security in project management	Y	Category-level mapping listed only the headline controls	R-004; VR-005
A.5.11	Return of assets	Y	Category-level mapping listed only the headline controls	R-003; VR-008
A.5.32	Intellectual property rights	Y	Category-level mapping listed only the headline controls	Legal / regulatory - NOT risk-based

Control	Title	Applicable	Why CGI-GAP-001 missed it	Now traced to
A.5.33	Protection of records	Y	Category-level mapping listed only the headline controls	R-003; VR-004
A.5.34	Privacy and protection of PII	Y	Category-level mapping listed only the headline controls	VR-001; VR-003; VR-006; R-003
A.6.1	Screening	Y	People controls were mapped only through PR.AT	R-003
A.6.2	Terms and conditions of employment	Y	People controls were mapped only through PR.AT	R-003
A.6.4	Disciplinary process	Y	People controls were mapped only through PR.AT	R-003; R-001
A.6.5	Responsibilities after termination or change of employment	Y	People controls were mapped only through PR.AT	R-003; VR-008
A.6.6	Confidentiality or non-disclosure agreements	Y	People controls were mapped only through PR.AT	R-003; VR-003
A.6.7	Remote working	Y	People controls were mapped only through PR.AT	R-001; R-003
A.7.1	Physical security perimeters	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Contractual / stakeholder - NOT risk-based
A.7.2	Physical entry	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Contractual / stakeholder - NOT risk-based
A.7.3	Securing offices, rooms and facilities	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Contractual / stakeholder - NOT risk-based
A.7.4	Physical security monitoring	N	Physical security was out of CGI-GAP-001 scope (section 1.4)	Excluded
A.7.5	Protecting against physical and environmental threats	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Contractual / stakeholder - NOT risk-based
A.7.6	Working in secure areas	N	Physical security was out of CGI-GAP-001 scope (section 1.4)	Excluded
A.7.7	Clear desk and clear screen	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Contractual / stakeholder - NOT risk-based
A.7.8	Equipment siting and protection	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Contractual / stakeholder - NOT risk-based
A.7.9	Security of assets off-premises	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Maturity gap
A.7.10	Storage media	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	R-003
A.7.11	Supporting utilities	N	Physical security was out of CGI-GAP-001 scope (section 1.4)	Excluded
A.7.12	Cabling security	N	Physical security was out of CGI-GAP-001 scope (section 1.4)	Excluded
A.7.13	Equipment maintenance	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Contractual / stakeholder - NOT risk-based
A.7.14	Secure disposal or re-use of equipment	Y	Physical security was out of CGI-GAP-001 scope (section 1.4)	Maturity gap + Legal
A.8.3	Information access restriction	Y	Category-level mapping listed only the headline controls	R-004
A.8.4	Access to source code	Y	Category-level mapping listed only the headline controls	R-004
A.8.6	Capacity management	Y	Category-level mapping listed only the headline controls	Contractual / stakeholder - NOT risk-based

Control	Title	Applicable	Why CGI-GAP-001 missed it	Now traced to
A.8.17	Clock synchronization	Y	Category-level mapping listed only the headline controls	R-003; VR-004
A.8.18	Use of privileged utility programs	Y	Category-level mapping listed only the headline controls	R-005; R-003
A.8.19	Installation of software on operational systems	Y	Category-level mapping listed only the headline controls	R-004; R-002
A.8.21	Security of network services	Y	Category-level mapping listed only the headline controls	R-005; VR-004
A.8.23	Web filtering	Y	Category-level mapping listed only the headline controls	R-001; R-002
A.8.26	Application security requirements	Y	Category-level mapping listed only the headline controls	R-004
A.8.27	Secure system architecture and engineering principles	Y	Category-level mapping listed only the headline controls	R-004; R-005; VR-002
A.8.30	Outsourced development	N	Category-level mapping listed only the headline controls	Excluded
A.8.33	Test information	Y	Category-level mapping listed only the headline controls	R-003; R-004
A.8.34	Protection of information systems during audit testing	Y	Category-level mapping listed only the headline controls	Contractual / stakeholder - NOT risk-based

3.5 Supplier relationships and cloud services — A.5.19 to A.5.23, and the honest GV.SC statement

GV.SC is a 2, not a 3. CGI-TPR-001 delivered a designed, owned and communicated supplier programme: 17 vendors tiered 7/6/4, a published tiering model, a 74-question questionnaire, onboarding Gates A–C, an 18-clause contract checklist and three completed assessments. **None of that is yet a cycle.** The first Tier 1 re-reviews fall due in September 2027, no sub-processor change feed is monitored (F-012), and the 14 KRIs have never been reported. Under the rule that an approved but unevidenced control is a 2, **A.5.19 to A.5.22 are maturity 2 (Partial)**. **A.5.23 is maturity 1**: there is no cloud-specific process or documented shared-responsibility boundary, and the one Tier 1 cloud assessment passed only with conditions that are all Cypher Group Inc.'s own (VRA-2026-001).

What this means for certification readiness:

Question	Answer
Does "Partial" block Stage 1?	No. Stage 1 checks that the controls are designed, owned and dated in the risk treatment plan. They are.
What will a Stage 2 auditor sample?	Operating evidence: onboarding decision records (CGI-VEN-017), the ChatCo re-assessment (15 Dec 2026), the CloudCo condition closures (C1–C4, 15 Dec 2026), quarterly shadow-IT reconciliations, KRI reports, and **the seven Tier 1 re-reviews due Sep 2027**.
Why Stage 2 is planned for October 2027	So the first Tier 1 review cycle has run. Before that, A.5.22 can only show a cadence that has never fired.
What would most likely become a nonconformity?	**Any of the six missing DPAs still open at Stage 2.** That breaks A.5.20 and A.5.34 and is a present-tense GDPR Article 28 gap. Depending on extent, an auditor could grade it major. **Deadline: 31 Oct 2026 (ISO-09).**
Is a Tier 1 vendor in FAIL status acceptable?	Only with a CEO-approved, expiring risk acceptance made against the criteria ISO-05 creates. ChatCo must be remediated or accepted before Stage 1.

3.6 Reconciliation with PR.PS = 0 and control gap CG-02

PR.PS traces to control gap CG-02 in CGI-RSK-001 section 4.3 (secure development and vulnerability management). CG-04 is recurring awareness training. The two are easy to confuse, so every row here was checked against the register (RC-06).

Control	Status	Why it cannot be anything else
A.5.7 Threat intelligence	Not started	ID.RA = 3 describes the register method; no threat intelligence exists, and CG-02 records that the register rests on workshop judgement
A.8.8 Technical vulnerabilities	Not started	CG-02: no scanning, no SLA, CGI-POL-008 unwritten; the endpoint patch clause is a fragment
A.8.25 Secure development life cycle	Not started	CG-02: CGI-POL-007 unwritten
A.8.28 Secure coding	Not started	No mandatory peer review, no branch protection (REC-06)
A.8.29 Security testing	Not started	No SAST, no penetration test (REC-16)
A.8.31 Separation of environments	Not started	No recorded separation
A.8.32 Change management	Not started	No change policy or approval record

The same rule puts **A.8.3, A.8.4, A.8.19 and A.8.26** (the controls CGI-GAP-001 missed on the code path) at Not started. **All eleven controls named in this section guard the code path behind R-004, and none of them is running.** That is why R-004 remains at residual 12 (High), and why REC-06 is the one date in the roadmap that cannot slip.

3.7 Candidate risks, proposed rather than invented

ID	Candidate risk (for the next CGI-RSK-001 review; NOT added here)	Controls it would justify	Why it is only a candidate
CR-01	Lost or stolen endpoint exposes Confidential data	A.7.9; A.8.1; A.8.24	No CGI-RSK-001 risk covers device loss on a BYOD estate of 50.
CR-02	Platform capacity exhaustion causes a customer-facing outage	A.8.6; A.8.14	Availability is covered only for ransomware (R-002) and vendor concentration (VR-002).
CR-03	Unauthorised physical access to the office	A.7.1; A.7.2; A.7.3	Physical security was out of scope in CGI-GAP-001.

3.8 The full Statement of Applicability

Paste-ready: **`05-iso27001-readiness-and-soa.csv`** (all columns). The governance columns (basis, maturity, CGI-GAP-001 mapping, roadmap link) are in section 3.9 and in the workbook.

A.5.1

Field	Value
Control	**A.5.1**
Title	Policies for information security
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Required by every register risk that relies on a written rule. Five topic-specific policies are approved (GV.PO = 2) but there is no top-level ISMS policy, 40% of staff have not acknowledged the pack and no annual review has run.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-001 to -005 v1.0 approved; CGI-TRK-001 (60% acknowledged). Required: CEO-approved ISMS policy; first annual review record; 100% acknowledgement.
Owner (job title)	Chief Executive Officer
Related CGI-RSK-001 v1.1 risk ID	R-001; R-002
Related CGI-GAP-001 Category	GV.PO; GV.OC; GV.RM
Related CGI-TPR-001 finding	-
Target date	31 Oct 2026

A.5.2

Field	Value
Control	**A.5.2**
Title	Information security roles and responsibilities
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Accountability exists per document (GV.RR = 2) and CGI-POL-005 section 4 names response roles, but no ISMS role, security programme lead or RACI across the controls exists.
Implementation status	**Partial**
Evidence held or required	Held: document control blocks; CGI-POL-005 section 4 roles; CGI-TPR-001 RACI. Required: ISMS RACI covering this SoA; written assignment of the security programme lead.
Owner (job title)	Chief Executive Officer
Related CGI-RSK-001 v1.1 risk ID	R-003
Related CGI-GAP-001 Category	GV.RR
Related CGI-TPR-001 finding	-
Target date	31 Oct 2026

A.5.3

Field	Value
Control	**A.5.3**
Title	Segregation of duties
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Policy approval is segregated (CGI-POL-002 approver moved to the CEO), but engineers can commit straight to production with no second person, which is the code-path duty conflict behind R-004.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-002 approval record. Required: segregation-of-duties matrix; CodeCo branch protection requiring a second reviewer.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004; R-003
Related CGI-GAP-001 Category	GV.RR
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.5.4

Field	Value
Control	**A.5.4**
Title	Management responsibilities
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Management must require staff to apply policy. CGI-TRK-001 shows 60% acknowledgement, so roughly 20 staff are bound by rules they have not read (GAP-004).
Implementation status	**Partial**
Evidence held or required	Held: CGI-TRK-001. Required: onboarding acknowledgement gate; CEO communication requiring compliance.
Owner (job title)	Chief Executive Officer
Related CGI-RSK-001 v1.1 risk ID	R-001; R-002

Field	Value
Related CGI-GAP-001 Category	GV.RR; GV.RM; GV.OC
Related CGI-TPR-001 finding	-
Target date	31 Dec 2026

A.5.5

Field	Value
Control	**A.5.5**
Title	Contact with authorities
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-005 section 5.6.3 commits to the GDPR 72-hour notification, but no lead supervisory authority or contact route is recorded (GAP-019), and F-002 shows the clock can start outside CGI's control.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-005 section 5.6.3. Required: authority contact register (supervisory authority, national CSIRT, police cyber unit).
Owner (job title)	Head of Customer Success
Related CGI-RSK-001 v1.1 risk ID	VR-004; R-005; R-003
Related CGI-GAP-001 Category	RS.CO; RC.CO
Related CGI-TPR-001 finding	F-002 (no vendor breach-notification clause)
Target date	31 Dec 2026

A.5.6

Field	Value
Control	**A.5.6**
Title	Contact with special interest groups
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Mapped by CGI-GAP-001 to RS.CO and RC.CO. No membership of any security community exists; also the practical feed for A.5.7.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: record of at least one membership (for example a national CERT advisory list or an OWASP chapter).
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	RS.CO; RC.CO
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.5.7

Field	Value
Control	**A.5.7**
Title	Threat intelligence
Theme	Organizational
Applicable Y/N	Y

Field	Value
Justification for inclusion or exclusion	ID.RA = 3 describes the register method, not threat intelligence. The register's coverage rests on workshop judgement with no technical or threat input (CG-02), so this control is Not started.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: named intelligence sources, a monthly review record and evidence that findings fed CGI-RSK-001.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-001; R-002; R-004
Related CGI-GAP-001 Category	ID.RA; PR.PS
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.5.8

Field	Value
Control	**A.5.8**
Title	Information security in project management
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. Features reach production with no security requirement step (R-004), and two AI tools entered the business with no project review (VR-005).
Implementation status	**Not started**
Evidence held or required	Held: none. Required: security requirements gate in CGI-POL-007; project intake checklist.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004; VR-005
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	CGI-VEN-012 and -013 adopted outside any project or procurement review
Target date	31 Mar 2027

A.5.9

Field	Value
Control	**A.5.9**
Title	Inventory of information and other associated assets
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	ID.AM = 1. The CGI-TPR-001 vendor inventory is one input; no inventory of CloudCo data stores, repositories, drives or endpoints exists.
Implementation status	**Partial**
Evidence held or required	Held: CGI-TPR-001 vendor inventory (17 rows). Required: asset and SaaS inventory with owner and CGI-POL-004 label per asset.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-003; R-005
Related CGI-GAP-001 Category	ID.AM
Related CGI-TPR-001 finding	17-vendor inventory (input only - not an asset inventory)
Target date	31 Mar 2027

A.5.10

Field	Value
Control	**A.5.10**
Title	Acceptable use of information and other associated assets
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-001 is approved, including section 4.5 on AI use, but 40% of staff have not acknowledged it and ScribeCo shows it being bypassed (VR-006).
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-001 v1.0. Required: 100% acknowledgement; AI-use briefing record.
Owner (job title)	Head of People and Operations
Related CGI-RSK-001 v1.1 risk ID	R-001; R-003; VR-006
Related CGI-GAP-001 Category	ID.AM; GV.PO
Related CGI-TPR-001 finding	CGI-VEN-012 ScribeCo used in breach of CGI-POL-001 section 4.5
Target date	31 Dec 2026

A.5.11

Field	Value
Control	**A.5.11**
Title	Return of assets
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. The rule is written: CGI-POL-001 section 4.11 requires devices, access cards and printed material back within five business days, and CGI-POL-003 section 4.5.9 requires a completed offboarding checklist for every leaver. Neither has been evidenced, and neither reaches company data held on BYOD devices or in non-federated vendor accounts.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-001 section 4.11; CGI-POL-003 sections 4.5.2 and 4.5.9. Required: completed offboarding checklists covering asset and data return and every non-federated vendor (CGI-TPR-001 Gate C).
Owner (job title)	Head of People and Operations
Related CGI-RSK-001 v1.1 risk ID	R-003; VR-008
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	F-003 (no SCIM on ChatCo; leaver removal manual)
Target date	31 Dec 2026

A.5.12

Field	Value
Control	**A.5.12**
Title	Classification of information
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-004 defines four tiers (confirmed, VA-01), but the scheme has not been applied to any asset (ID.AM = 1).
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-004 v1.0. Required: classification recorded against every inventory entry; approved section 4.2 amendment.

Field	Value
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-003; R-005
Related CGI-GAP-001 Category	ID.AM; PR.DS
Related CGI-TPR-001 finding	CGI-POL-004 section 4.2 named no third-party destinations (CGI-TPR-001 section 1.1)
Target date	31 Mar 2027

A.5.13

Field	Value
Control	**A.5.13**
Title	Labelling of information
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	No asset carries a classification label, so the Handling Matrix cannot be enforced (GAP-007).
Implementation status	**Partial**
Evidence held or required	Held: labelling rules in CGI-POL-004. Required: labels applied in OfficeCo, repositories and data stores.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-003
Related CGI-GAP-001 Category	ID.AM
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.5.14

Field	Value
Control	**A.5.14**
Title	Information transfer
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	The CGI-POL-004 Handling Matrix governs transfer, but it named no permitted third-party destinations until the CGI-TPR-001 amendment, which is still awaiting approval.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-004 section 4.2. Required: CTO-approved amendment listing permitted destinations by classification.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-003; VR-001; VR-003; VR-006
Related CGI-GAP-001 Category	PR.DS
Related CGI-TPR-001 finding	F-001; F-004; CGI-POL-004 section 4.2 named no third-party destinations
Target date	31 Oct 2026

A.5.15

Field	Value
Control	**A.5.15**
Title	Access control
Theme	Organizational

Field	Value
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-003 is an approved access control policy (PR.AA = 2). It has never been evidenced operating, and the four-hour SLA cannot be met on non-federated vendors.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-003 v1.0. Required: first quarterly review record; SSO coverage list.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-001; R-003; VR-008
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	F-003
Target date	31 Dec 2026

A.5.16

Field	Value
Control	**A.5.16**
Title	Identity management
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	OfficeCo is the identity provider (VRA addendum step 3), but ChatCo, WikiCo, WriteCo and WhiteboardCo are not federated, so identity lifecycle is incomplete.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-003 JML process. Required: SSO/SCIM on Tier 1 vendors (ChatCo by 15 Nov 2026); KRI-V5 at 100%.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-001; R-003; VR-008
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	F-003; KRI-V5
Target date	31 Dec 2026

A.5.17

Field	Value
Control	**A.5.17**
Title	Authentication information
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-002 sections 4.3 and 4.5 are strong, but MFA enrolment is 80% and ACC-001 still accepts SMS until 03 Mar 2027.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-002; CGI-TRK-001 (80% MFA); ACC-001. Required: 100% enrolment report; ACC-001 retired.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-001
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	F-010 (root-account MFA CUEC unaccepted)
Target date	31 Dec 2026

A.5.18

Field	Value
Control	**A.5.18**
Title	Access rights
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	The CGI-POL-003 section 4.7.1 quarterly privileged review is mandated but has never run; the CloudCo report assumes CGI performs this review (CUEC).
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-003 section 4.7.1. Required: dated, signed quarterly review records (four by Stage 2).
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-003; R-005; VR-008
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	F-010 (least-privilege review CUEC); F-003
Target date	31 Dec 2026

A.5.19

Field	Value
Control	**A.5.19**
Title	Information security in supplier relationships
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-TPR-001 is the supplier process, so GV.SC = 2 (designed, owned, communicated). It is not 3: no review cycle has run on cadence, and the first Tier 1 re-reviews fall due Sep 2027.
Implementation status	**Partial**
Evidence held or required	Held: CGI-TPR-001 v1.0; VRA-2026-001/-002/-003. Required for Implemented: seven Tier 1 review records; four quarterly shadow-IT reconciliations; KRI reports.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	VR-001; VR-002; VR-003; VR-004; VR-005; VR-006; VR-007; VR-008; VR-009; R-005
Related CGI-GAP-001 Category	GV.SC
Related CGI-TPR-001 finding	Estate 17 vendors vs 5 known; 2 AI tools found only through expense claims, with no company contract; 4 of 17 with no assurance artifact
Target date	30 Sep 2027

A.5.20

Field	Value
Control	**A.5.20**
Title	Addressing information security within supplier agreements
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	The 18-clause checklist and Gate B (no DPA, no onboarding) are designed. 6 of 17 vendors still have no executed DPA, which is a live GDPR Article 28 gap and a likely Stage 2 finding if still open.
Implementation status	**Partial**
Evidence held or required	Held: CGI-TPR-001 section 7.4 checklist; 11 executed DPAs. Required: six outstanding DPAs executed; KRI-V1 at 100%.
Owner (job title)	Chief Technology Officer

Field	Value
Related CGI-RSK-001 v1.1 risk ID	VR-001; VR-004; VR-006; VR-007
Related CGI-GAP-001 Category	GV.SC
Related CGI-TPR-001 finding	F-001; F-002; F-004; F-005; F-009 (no audit right - accepted); KRI-V1 = 65% (6 of 17 vendors with no DPA)
Target date	31 Oct 2026

A.5.21

Field	Value
Control	**A.5.21**
Title	Managing information security in the ICT supply chain
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Questionnaire domain 7 and clauses 4-5 design the ICT supply-chain control, but fourth parties behind carve-out reports have never been reconciled.
Implementation status	**Partial**
Evidence held or required	Held: CGI-TPR-002 VQ-33 to VQ-36. Required: CSOC reconciliation records for CloudCo and ChatCo.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	VR-003; VR-004
Related CGI-GAP-001 Category	GV.SC
Related CGI-TPR-001 finding	F-007; F-011 (CSOC lists never reconciled)
Target date	31 Dec 2026

A.5.22

Field	Value
Control	**A.5.22**
Title	Monitoring, review and change management of supplier services
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Review cadence is defined (12/18/24 months) and clause 9 treats assurance decay, but zero scheduled reviews have run and no change feed is monitored.
Implementation status	**Partial**
Evidence held or required	Held: CGI-TPR-001 tiering model and KRIs. Required: dated review records; sub-processor change-feed subscriptions.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	VR-003; VR-009
Related CGI-GAP-001 Category	GV.SC
Related CGI-TPR-001 finding	F-006 (stale ChatCo SOC 2); F-012 (sub-processor feed not subscribed)
Target date	30 Sep 2027

A.5.23

Field	Value
Control	**A.5.23**
Title	Information security for use of cloud services
Theme	Organizational

Field	Value
Applicable Y/N	Y
Justification for inclusion or exclusion	Cloud acquisition is covered by CGI-TPR-001, but there is no cloud-specific process, no documented shared-responsibility boundary and no tested exit, and the four CUECs are unaccepted, so the CloudCo opinion does not yet cover CGI's use.
Implementation status	**Partial**
Evidence held or required	Held: VRA-2026-001. Required: signed CUEC acceptance (C1); shared-responsibility statement; exit plan for Tier 1 cloud vendors (KRI-V7).
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-005; VR-002; VR-004; VR-007
Related CGI-GAP-001 Category	GV.SC; PR.IR
Related CGI-TPR-001 finding	VRA-2026-001 CloudCo PASS WITH CONDITIONS (F-010 to F-013; all four conditions are CGI's)
Target date	15 Dec 2026

A.5.24

Field	Value
Control	**A.5.24**
Title	Information security incident management planning and preparation
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-005 is an approved plan with SEV1-SEV4, roles and targets (RS.MA = 2), but it has never been exercised and names no out-of-band channel.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-005 v1.0. Required: tabletop record; vendor incident contacts; out-of-band channel.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-002; R-005; VR-004
Related CGI-GAP-001 Category	RS.MA; RS.CO
Related CGI-TPR-001 finding	F-002; VR-002 (out-of-band incident channel needed)
Target date	30 Jun 2027

A.5.25

Field	Value
Control	**A.5.25**
Title	Assessment and decision on information security events
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	SEV bands exist, but with no telemetry and no alert-to-incident escalation, there is nothing to assess (DE.AE = 1).
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-005 SEV definitions. Required: written triage and escalation path; sample triage tickets.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-001; R-003
Related CGI-GAP-001 Category	DE.AE
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.5.26

Field	Value
Control	**A.5.26**
Title	Response to information security incidents
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	The CGI-POL-005 section 5.5 response stages are written, but no containment runbooks exist and no response has ever been performed or rehearsed.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-005 section 5.5. Required: runbooks for the top three scenarios; exercise record.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-001; R-002; R-005; VR-004
Related CGI-GAP-001 Category	RS.MA; RS.MI
Related CGI-TPR-001 finding	F-002; F-008
Target date	30 Jun 2027

A.5.27

Field	Value
Control	**A.5.27**
Title	Learning from information security incidents
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	The CGI-POL-005 sections 5.7 and 7.2 reviews and tabletop are written but have never run (ID.IM = 1).
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-005 sections 5.7 and 7.2. Required: lessons-learned record from the first tabletop.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-002
Related CGI-GAP-001 Category	ID.IM; RS.AN
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.5.28

Field	Value
Control	**A.5.28**
Title	Collection of evidence
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-005 section 5.3.2 forbids deleting evidence, but no collection or chain-of-custody procedure or log retention standard sits beneath it.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-005 sections 5.3.2 and 5.7.3. Required: evidence-handling procedure; 12-month log retention standard.
Owner (job title)	IT Operations Manager

Field	Value
Related CGI-RSK-001 v1.1 risk ID	R-003; R-004; VR-004
Related CGI-GAP-001 Category	RS.AN
Related CGI-TPR-001 finding	F-008 (no customer-accessible ChatCo audit log)
Target date	31 Mar 2027

A.5.29

Field	Value
Control	**A.5.29**
Title	Information security during disruption
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	There is no plan for maintaining security during disruption. Concentration means one CloudCo regional failure also removes monitoring, ticketing and runbooks.
Implementation status	**Partial**
Evidence held or required	Held: CloudCo snapshots only. Required: disruption plan naming the out-of-band tools; status page (CGI-VEN-017) live.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-002; VR-002
Related CGI-GAP-001 Category	RC.RP; RC.CO
Related CGI-TPR-001 finding	VR-002 concentration: 5 vendors share CloudCo with the platform
Target date	30 Jun 2027

A.5.30

Field	Value
Control	**A.5.30**
Title	ICT readiness for business continuity
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Backups exist but have never been restored, and no RTO or RPO is declared (CG-01). CGI-RSK-001 gives R-002 no backup credit until this closes.
Implementation status	**Partial**
Evidence held or required	Held: CloudCo native snapshots. Required: CGI-POL-006 with RTO/RPO; dated restore test report.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-002; VR-002; VR-007
Related CGI-GAP-001 Category	RC.RP
Related CGI-TPR-001 finding	F-013 (no RTO/RPO, no restore test, export never exercised)
Target date	15 Dec 2026

A.5.31

Field	Value
Control	**A.5.31**
Title	Legal, statutory, regulatory and contractual requirements
Theme	Organizational
Applicable Y/N	Y

Field	Value
Justification for inclusion or exclusion	Obligations are scattered (GDPR processor role in assumption A-06, 72-hour duty in CGI-POL-005). No register of legal, regulatory and contractual requirements exists (GV.OC = 1).
Implementation status	**Partial**
Evidence held or required	Held: CGI-RSK-001 assumptions A-01 to A-06. Required: CEO-approved obligations register.
Owner (job title)	Chief Executive Officer
Related CGI-RSK-001 v1.1 risk ID	VR-001
Related CGI-GAP-001 Category	GV.OC
Related CGI-TPR-001 finding	F-001 (GDPR Art. 28 non-conformity)
Target date	31 Oct 2026

A.5.32

Field	Value
Control	**A.5.32**
Title	Intellectual property rights
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	No register risk covers this, and it is not in CGI-GAP-001. Included because a SaaS company ships third-party and open-source code under licence terms, and the inventory shows tools bought on personal expenses (CGI-VEN-013).
Implementation status	**Not started**
Evidence held or required	Held: CGI-POL-001 section 4.6.2 bans unlicensed software on devices (a fragment). Required: software licence register; open-source licence rule in CGI-POL-007.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.5.33

Field	Value
Control	**A.5.33**
Title	Protection of records
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001, although CGI-POL-004 section 7 maps it. No retention standard exists for ISMS records or logs, and one Tier 1 vendor retains everything indefinitely.
Implementation status	**Not started**
Evidence held or required	Held: retention periods by tier in CGI-POL-004 section 4.2, and two record-specific rules (CGI-POL-003 section 4.7.4; CGI-POL-005 section 5.7.5). These are fragments: no schedule covers ISMS records, logs or contracts. Required: records and retention schedule (ISMS records, logs, contracts).
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-003; VR-004
Related CGI-GAP-001 Category	RS.AN
Related CGI-TPR-001 finding	F-005 (ChatCo unlimited retention)
Target date	31 Mar 2027

A.5.34

Field	Value
Control	**A.5.34**
Title	Privacy and protection of PII
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001, although CGI is a GDPR processor for ~200 customers. Classification and breach duties exist, but there is no GDPR Article 30 record of processing and 6 vendors have no DPA.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-004; CGI-POL-005 section 5.6.3. Required: GDPR Art. 30 record of processing; six DPAs; transfer register.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	VR-001; VR-003; VR-006; R-003
Related CGI-GAP-001 Category	GV.OC; PR.DS
Related CGI-TPR-001 finding	F-001; F-004; O-001; KRI-V1 = 65%
Target date	31 Dec 2026

A.5.35

Field	Value
Control	**A.5.35**
Title	Independent review of information security
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	No independent review has ever taken place (GV.OV = 1). This assessment is internal and does not count.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: independent internal audit report (ISO-12).
Owner (job title)	Chief Executive Officer
Related CGI-RSK-001 v1.1 risk ID	R-004; R-005
Related CGI-GAP-001 Category	GV.OV
Related CGI-TPR-001 finding	-
Target date	31 May 2027

A.5.36

Field	Value
Control	**A.5.36**
Title	Compliance with policies, rules and standards for information security
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	No compliance check against policy has ever run. Acknowledgement is 60% and KRIs have never been reported.
Implementation status	**Partial**
Evidence held or required	Held: CGI-TRK-001. Required: quarterly compliance check minuted at the REC-10 review.
Owner (job title)	Chief Technology Officer

Field	Value
Related CGI-RSK-001 v1.1 risk ID	R-001; R-002
Related CGI-GAP-001 Category	GV.PO; GV.OV
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.5.37

Field	Value
Control	**A.5.37**
Title	Documented operating procedures
Theme	Organizational
Applicable Y/N	Y
Justification for inclusion or exclusion	Policies exist, but the procedures beneath them do not (GAP-017, GAP-020), and the planned runbook location shares CloudCo with the platform.
Implementation status	**Partial**
Evidence held or required	Held: policy pack only. Required: runbooks, stored where they survive a platform outage.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-002; R-005; VR-002
Related CGI-GAP-001 Category	GV.PO
Related CGI-TPR-001 finding	CGI-VEN-011 WikiCo holds runbooks: no DPA, public links enabled, CloudCo-hosted
Target date	30 Jun 2027

A.6.1

Field	Value
Control	**A.6.1**
Title	Screening
Theme	People
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. CGI-POL-003 joiner steps exist (a weak mapping kept from Project 1), but no proportionate screening procedure is evidenced.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-003 joiner section. Required: screening procedure lawful under EU/German employment law; sample records.
Owner (job title)	Head of People and Operations
Related CGI-RSK-001 v1.1 risk ID	R-003
Related CGI-GAP-001 Category	GV.RR
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.6.2

Field	Value
Control	**A.6.2**
Title	Terms and conditions of employment
Theme	People
Applicable Y/N	Y

Field	Value
Justification for inclusion or exclusion	Missed by CGI-GAP-001. No evidence that employment or contractor terms state information security responsibilities.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: contract clause referencing the ISMS policy and CGI-POL-001.
Owner (job title)	Head of People and Operations
Related CGI-RSK-001 v1.1 risk ID	R-003
Related CGI-GAP-001 Category	GV.RR
Related CGI-TPR-001 finding	-
Target date	31 Dec 2026

A.6.3

Field	Value
Control	**A.6.3**
Title	Information security awareness, education and training
Theme	People
Applicable Y/N	Y
Justification for inclusion or exclusion	Induction only, 60% complete, with no recurring or role-based training and no phishing simulation (CG-04, PR.AT = 1).
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-003 section 4.3.6; CGI-TRK-001. Required: annual curriculum; simulation results; AI-use module.
Owner (job title)	Head of People and Operations
Related CGI-RSK-001 v1.1 risk ID	R-001; VR-005; VR-006
Related CGI-GAP-001 Category	PR.AT
Related CGI-TPR-001 finding	VR-006: no staff instruction on CGI-POL-001 section 4.5 AI use
Target date	31 Mar 2027

A.6.4

Field	Value
Control	**A.6.4**
Title	Disciplinary process
Theme	People
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. No disciplinary procedure linked to policy breaches is on file, and unacknowledged policies are unenforceable (GAP-004).
Implementation status	**Not started**
Evidence held or required	Held: the sanction statement in each policy's Enforcement section (a fragment: there is no procedure behind it). Required: HR procedure referencing the CGI-POL pack.
Owner (job title)	Head of People and Operations
Related CGI-RSK-001 v1.1 risk ID	R-003; R-001
Related CGI-GAP-001 Category	GV.PO
Related CGI-TPR-001 finding	-
Target date	31 Dec 2026

A.6.5

Field	Value

Field	Value
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	F-003; VR-008
Target date	31 Dec 2026

A.6.6

Field	Value
Control	**A.6.6**
Title	Confidentiality or non-disclosure agreements
Theme	People
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. No signed confidentiality agreements are on file for staff or contractors.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: signed NDAs, reviewed annually (the control's own wording requires them documented).
Owner (job title)	Head of People and Operations
Related CGI-RSK-001 v1.1 risk ID	R-003; VR-003
Related CGI-GAP-001 Category	GV.RR
Related CGI-TPR-001 finding	-
Target date	31 Dec 2026

A.6.7

Field	Value
Control	**A.6.7**
Title	Remote working
Theme	People
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. CGI-POL-001 section 4.4 (BYOD) is an approved remote-working rule set, but there is no device register behind it.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-001 section 4.4. Required: endpoint register; remote-working compliance check.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-001; R-003
Related CGI-GAP-001 Category	GV.PO; PR.AA
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.6.8

Field	Value
Control	**A.6.8**
Title	Information security event reporting
Theme	People
Applicable Y/N	Y

Field	Value
Justification for inclusion or exclusion	CGI-POL-005 section 5.2 reporting channels are approved, but no event has been reported or rehearsed.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-005 section 5.2. Required: incident register entries; tabletop record.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-001; R-003; VR-004
Related CGI-GAP-001 Category	PR.AT; RS.CO
Related CGI-TPR-001 finding	F-002
Target date	30 Jun 2027

A.7.1

Field	Value
Control	**A.7.1**
Title	Physical security perimeters
Theme	Physical
Applicable Y/N	Y
Justification for inclusion or exclusion	No register risk covers physical intrusion, and physical security was out of CGI-GAP-001 scope. Applicable because the head office holds staff endpoints; enterprise questionnaires ask this (CGI asks it of vendors: VQ-64 to VQ-66). Candidate risk CR-03 is proposed rather than invented.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: landlord security schedule (assumption ISO-A03).
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.7.2

Field	Value
Control	**A.7.2**
Title	Physical entry
Theme	Physical
Applicable Y/N	Y
Justification for inclusion or exclusion	As A.7.1. Building entry is assumed to be provided by the landlord and is not evidenced.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: access badge process; visitor log.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.7.3

Field	Value

A.7.4

Field	Value
Control	**A.7.4**
Title	Physical security monitoring
Theme	Physical
Applicable Y/N	N
Justification for inclusion or exclusion	EXCLUDED. There are no secure areas or on-premises information processing facilities: production runs in CloudCo, whose physical monitoring is assured through A.5.23 (VRA-2026-001). The serviced office holds only portable endpoints. Re-include if servers, network equipment or Confidential paper records are kept on site.
Implementation status	**N/A - excluded**
Evidence held or required	Held: VRA-2026-001 (CloudCo SOC 2 covers data-centre monitoring). Required: exclusion approved in SoA v1.0.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	N/A - re-evaluate at SoA review 30 Sep 2027

A.7.5

Field	Value
Control	**A.7.5**
Title	Protecting against physical and environmental threats
Theme	Physical
Applicable Y/N	Y
Justification for inclusion or exclusion	No register risk covers this. It is applicable only to people and endpoints in the office (landlord fire and flood controls); production resilience is covered by A.5.23 and A.8.14.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: landlord fire-safety confirmation.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.7.6

Field	Value
Control	**A.7.6**
Title	Working in secure areas
Theme	Physical
Applicable Y/N	N
Justification for inclusion or exclusion	EXCLUDED. No secure areas are defined, because there is no server or network room. Re-include if one is created.
Implementation status	**N/A - excluded**
Evidence held or required	Held: n/a. Required: exclusion approved in SoA v1.0.
Owner (job title)	IT Operations Manager

Field	Value
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	N/A - re-evaluate at SoA review 30 Sep 2027

A.7.7

Field	Value
Control	**A.7.7**
Title	Clear desk and clear screen
Theme	Physical
Applicable Y/N	Y
Justification for inclusion or exclusion	No register risk covers shoulder-surfing or unattended screens; included as a baseline expected by customers and auditors. The rule already exists: CGI-POL-001 sections 4.4.2 (automatic screen lock), 4.8.2 (no unattended Confidential printouts) and 4.9.3 (lock the device when stepping away), which CGI-POL-001 section 8 maps to A.7.7. It is approved but unevidenced, and 40% of staff have not acknowledged it.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-001 sections 4.4.2, 4.8.2 and 4.9.3. Required: 100% acknowledgement; screen-lock configuration evidence; clear-desk spot-check record.
Owner (job title)	Head of People and Operations
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	31 Dec 2026

A.7.8

Field	Value
Control	**A.7.8**
Title	Equipment siting and protection
Theme	Physical
Applicable Y/N	Y
Justification for inclusion or exclusion	No register risk covers this. Applicable to endpoints in the office and at home; included on a baseline and stakeholder basis.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: guidance within the remote-working rules.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.7.9

Field	Value
Control	**A.7.9**
Title	Security of assets off-premises
Theme	Physical

Field	Value
Applicable Y/N	Y
Justification for inclusion or exclusion	Relates to ID.AM (no endpoint register, score 1). CGI-POL-001 section 4.4 covers device use off-site. Candidate risk CR-01 (lost or stolen endpoint) is recommended for the register.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-001 section 4.4. Required: endpoint register; full-disk encryption evidence.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	ID.AM
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.7.10

Field	Value
Control	**A.7.10**
Title	Storage media
Theme	Physical
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. The CGI-POL-004 section 4.2 Handling Matrix governs removable media, and EXC-003 records an approved exception, so the rule is designed and exercised through the exception process.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-004 section 4.2; EXC-003. Required: media usage record.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-003
Related CGI-GAP-001 Category	PR.DS
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.7.11

Field	Value
Control	**A.7.11**
Title	Supporting utilities
Theme	Physical
Applicable Y/N	N
Justification for inclusion or exclusion	EXCLUDED. No information processing facility is operated, so there are no utilities to protect. Power and cooling for production are CloudCo's responsibility, assured through A.5.23 (VRA-2026-001).
Implementation status	**N/A - excluded**
Evidence held or required	Held: VRA-2026-001. Required: exclusion approved in SoA v1.0.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	N/A - re-evaluate at SoA review 30 Sep 2027

A.7.12

Field	Value
Control	**A.7.12**
Title	Cabling security
Theme	Physical
Applicable Y/N	N
Justification for inclusion or exclusion	EXCLUDED. There is no on-premises network cabling carrying production data. Office connectivity is the landlord's shared service, and platform networking is covered by A.8.20 to A.8.22.
Implementation status	**N/A - excluded**
Evidence held or required	Held: n/a. Required: exclusion approved in SoA v1.0.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	N/A - re-evaluate at SoA review 30 Sep 2027

A.7.13

Field	Value
Control	**A.7.13**
Title	Equipment maintenance
Theme	Physical
Applicable Y/N	Y
Justification for inclusion or exclusion	No register risk covers this. Applicable to endpoints. The CGI-POL-001 section 4.4.3 patch rule is a software fragment, not maintenance, so it does not change the status.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: endpoint maintenance and repair rule (data wiped before third-party repair).
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.7.14

Field	Value
Control	**A.7.14**
Title	Secure disposal or re-use of equipment
Theme	Physical
Applicable Y/N	Y
Justification for inclusion or exclusion	Relates to ID.AM (asset lifecycle, score 1). GDPR Article 32 requires secure disposal of personal data on retired devices. No procedure exists.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: wipe or destruction record per retired device.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	ID.AM

Field	Value
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.1

Field	Value
Control	**A.8.1**
Title	User endpoint devices
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-001 section 4.4 BYOD rules exist, but there is no register and no management tooling for the 50 staff devices (ID.AM = 1).
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-001 section 4.4. Required: endpoint register; encryption and screen-lock compliance report.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-001; R-002; R-003
Related CGI-GAP-001 Category	ID.AM
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.2

Field	Value
Control	**A.8.2**
Title	Privileged access rights
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	CGI-POL-002 section 4.3.3 mandates phishing-resistant MFA for privileged accounts, but the CGI-POL-003 section 4.7.1 quarterly review has never run and the CloudCo root-account CUEC is unaccepted.
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-002 section 4.3.3. Required: privileged account list; quarterly review records; root MFA evidence.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-005; R-003; R-001
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	F-010 (root MFA and least-privilege CUECs)
Target date	31 Dec 2026

A.8.3

Field	Value
Control	**A.8.3**
Title	Information access restriction
Theme	Technological
Applicable Y/N	Y

Field	Value
Justification for inclusion or exclusion	Missed by CGI-GAP-001, and the most important omission: R-004 is an application authorisation flaw, which is this control. No authorisation design standard or test exists (PR.PS = 0). CGI asks vendors for tenant isolation (VQ-24) that it cannot yet evidence itself.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: authorisation and tenant-isolation design standard; test cases; REC-16 penetration test result.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004
Related CGI-GAP-001 Category	PR.PS; PR.AA
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.4

Field	Value
Control	**A.8.4**
Title	Access to source code
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. CGI-POL-002 section 4.5.2 secret scanning is a recorded fragment, but repository access and write rights are uncontrolled. Kept at Not started to agree with PR.PS = 0.
Implementation status	**Not started**
Evidence held or required	Held: CGI-POL-002 section 4.5.2 (fragment). Required: repository access review; branch protection configuration export.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	CGI-VEN-002 CodeCo: Tier 1, inherent 15 Critical, no branch protection on the CGI side
Target date	31 Mar 2027

A.8.5

Field	Value
Control	**A.8.5**
Title	Secure authentication
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	MFA is mandated and 80% enrolled; ACC-001 accepts SMS until 03 Mar 2027. This is a brakes control: it acts before the break-in.
Implementation status	**Partial**
Evidence held or required	Held: CGI-TRK-001 (80%). Required: 100% enrolment export; phishing-resistant MFA on all admins.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-001
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	F-003 (no SSO on ChatCo); F-010
Target date	31 Dec 2026

A.8.6

Field	Value
Control	**A.8.6**
Title	Capacity management
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	No register risk covers capacity exhaustion, and CGI-GAP-001 does not map it. Included because ~200 customers depend on platform availability (assumption ISO-A04); CGI already asks this of its own vendors (VQ-55). Candidate risk CR-02 is proposed rather than invented.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: capacity monitoring thresholds; quarterly capacity review.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.8.7

Field	Value
Control	**A.8.7**
Title	Protection against malware
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	No anti-malware standard covers the 50 BYOD endpoints (GAP-020).
Implementation status	**Not started**
Evidence held or required	Held: CGI-POL-001 section 4.2.3 forbids disabling endpoint protection (a fragment: nothing requires it to be installed or checks that it is). Required: endpoint protection standard; coverage report.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-002; R-001
Related CGI-GAP-001 Category	RS.MI
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.8

Field	Value
Control	**A.8.8**
Title	Management of technical vulnerabilities
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	PR.PS = 0 and CG-02: no scanning, no remediation SLA, CGI-POL-008 unwritten. The endpoint patch rule (CGI-POL-001 section 4.4.3) is a fragment that does not cover the platform, so the status is Not started.
Implementation status	**Not started**
Evidence held or required	Held: CGI-POL-001 section 4.4.3 (fragment). Required: CGI-POL-008; authenticated scan reports; remediation tickets within SLA.
Owner (job title)	Chief Technology Officer

Field	Value
Related CGI-RSK-001 v1.1 risk ID	R-002; R-004
Related CGI-GAP-001 Category	PR.PS; ID.RA
Related CGI-TPR-001 finding	CG-02
Target date	31 Mar 2027

A.8.9

Field	Value
Control	**A.8.9**
Title	Configuration management
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	CG-03: there is no CloudCo configuration baseline and no drift detection (PR.IR = 0). This is the documented reason R-005 stays High.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: CIS AWS Foundations baseline; posture-monitoring reports.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-005; R-004
Related CGI-GAP-001 Category	PR.PS; PR.IR
Related CGI-TPR-001 finding	F-010; CG-03
Target date	30 Jun 2027

A.8.10

Field	Value
Control	**A.8.10**
Title	Information deletion
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Deletion is designed for vendor exits (clause 12, VQ-73) but not for CGI's own systems: no retention or deletion schedule has been executed (GAP-012).
Implementation status	**Partial**
Evidence held or required	Held: CGI-POL-004 section 4.2 retention limits and disposal methods (designed, never executed); CGI-TPR-001 clause 12. Required: retention and deletion schedule; deletion certificates.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-003; VR-001; VR-006
Related CGI-GAP-001 Category	PR.DS
Related CGI-TPR-001 finding	F-005; clause 12 (certified deletion) in CGI-TPR-001 section 7.4
Target date	31 Mar 2027

A.8.11

Field	Value
Control	**A.8.11**
Title	Data masking
Theme	Technological
Applicable Y/N	Y

Field	Value
Justification for inclusion or exclusion	There is no masking of customer data in logs or lower environments; Project 1's mapping to the Handling Matrix was weak and is not credited.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: masking rule for logs and test data; MonitorCo scrubbing configuration.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-003; VR-004
Related CGI-GAP-001 Category	PR.DS
Related CGI-TPR-001 finding	CGI-VEN-007 MonitorCo: log scrubbing rules not verified
Target date	30 Jun 2027

A.8.12

Field	Value
Control	**A.8.12**
Title	Data leakage prevention
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	CG-05: there is no data-loss prevention; monitoring is metadata-only.
Implementation status	**Not started**
Evidence held or required	Held: CGI-POL-001 section 4.5.2, a behavioural rule against entering Confidential data into unapproved AI tools (a fragment, not leakage prevention). Required: egress and DLP rules on OfficeCo and CodeCo; alert samples.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-003
Related CGI-GAP-001 Category	PR.DS; DE.CM
Related CGI-TPR-001 finding	VR-006 (AI tools reading typed text)
Target date	30 Sep 2027

A.8.13

Field	Value
Control	**A.8.13**
Title	Information backup
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Seatbelt, not brakes: backup acts after the bang, limiting the impact of R-002 ransomware. Snapshots exist but have never been restored (CG-01), so no credit is taken.
Implementation status	**Partial**
Evidence held or required	Held: CloudCo snapshot configuration. Required: CGI-POL-006; dated restore test to a clean environment; six-monthly repeat.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-002; VR-002
Related CGI-GAP-001 Category	PR.IR; RC.RP
Related CGI-TPR-001 finding	F-013; VRA-2026-001 C4
Target date	15 Dec 2026

A.8.14

Field	Value
Control	**A.8.14**
Title	Redundancy of information processing facilities
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	No redundancy design is documented for the platform. The status-page placement is a design-time fragment only.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: availability architecture record (zones and regions); failover test.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-002; VR-002
Related CGI-GAP-001 Category	PR.IR
Related CGI-TPR-001 finding	VR-002; CGI-VEN-017 deliberately hosted off CloudCo
Target date	30 Jun 2027

A.8.15

Field	Value
Control	**A.8.15**
Title	Logging
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Some logs exist ad hoc (application logs in MonitorCo), but organisation-wide CloudTrail is unverified and there is no central security log or retention (DE.CM = 1).
Implementation status	**Partial**
Evidence held or required	Held: MonitorCo APM (engineering use). Required: CloudTrail with validation; central log account; retention standard.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-003; R-005; VR-004
Related CGI-GAP-001 Category	DE.CM; DE.AE; RS.AN
Related CGI-TPR-001 finding	F-008; F-010 (CloudTrail CUEC); CGI-VEN-007 not a security log source
Target date	31 Mar 2027

A.8.16

Field	Value
Control	**A.8.16**
Title	Monitoring activities
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	There is no alerting on root use, IAM change, public S3 or mass download (GAP-015).
Implementation status	**Not started**
Evidence held or required	Held: CGI-POL-001 section 4.10 monitoring notice (a fragment: it tells staff monitoring may occur, but no alert exists). Required: alert rules; alert-handling records.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-003; R-005
Related CGI-GAP-001 Category	DE.CM; DE.AE

Field	Value
Related CGI-TPR-001 finding	F-010
Target date	31 Mar 2027

A.8.17

Field	Value
Control	**A.8.17**
Title	Clock synchronization
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. A supporting control: logs without a common time source cannot support A.5.28 investigations. The provider time source is assumed but not verified.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: configuration evidence of a common time source.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-003; VR-004
Related CGI-GAP-001 Category	DE.CM; RS.AN
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.18

Field	Value
Control	**A.8.18**
Title	Use of privileged utility programs
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. Administrative tooling with broad IAM rights is unrestricted and unrecorded.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: list of privileged tools and who may use them.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-005; R-003
Related CGI-GAP-001 Category	PR.AA
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.8.19

Field	Value
Control	**A.8.19**
Title	Installation of software on operational systems
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. Software reaches production with no controlled release process (PR.PS = 0).
Implementation status	**Not started**

Field	Value
Evidence held or required	Held: CGI-POL-001 section 4.6.2 (an endpoint software rule; a fragment that does not reach production). Required: release procedure in CGI-POL-007; deployment pipeline records.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004; R-002
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.20

Field	Value
Control	**A.8.20**
Title	Networks security
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	There is no network security baseline (CG-03, PR.IR = 0).
Implementation status	**Not started**
Evidence held or required	Held: none. Required: security-group and VPC baseline; review record.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-005
Related CGI-GAP-001 Category	PR.IR
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.8.21

Field	Value
Control	**A.8.21**
Title	Security of network services
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. Security requirements for the network services consumed (VPC, DNS, TLS endpoints) are not defined.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: network service requirements; provider evidence mapped.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-005; VR-004
Related CGI-GAP-001 Category	PR.IR
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.8.22

Field	Value
Control	**A.8.22**
Title	Segregation of networks
Theme	Technological
Applicable Y/N	Y

Field	Value
Justification for inclusion or exclusion	Segmentation is undocumented (GAP-014). The remediation stays at Q4 2027 in the risk treatment plan; the boundary documentation moves forward into ISO-02.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: segmentation diagram; production access boundary.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-005; R-004
Related CGI-GAP-001 Category	PR.IR
Related CGI-TPR-001 finding	-
Target date	31 Dec 2027

A.8.23

Field	Value
Control	**A.8.23**
Title	Web filtering
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. There is no web filtering on BYOD endpoints; a DNS-filtering option is proposed.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: filtering configuration; coverage report.
Owner (job title)	IT Operations Manager
Related CGI-RSK-001 v1.1 risk ID	R-001; R-002
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

A.8.24

Field	Value
Control	**A.8.24**
Title	Use of cryptography
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Seatbelt control: it reduces the impact of a stolen copy (VR-004). There is no encryption standard (GAP-012). Server-side encryption does NOT reduce the impact of a public-bucket misconfiguration (R-005), because the service decrypts for any request the misconfiguration allows.
Implementation status	**Not started**
Evidence held or required	Held: CGI-POL-004 section 4.2 says where encryption is required and CGI-POL-001 section 4.4.1 requires disk encryption on devices (fragments: no algorithms, TLS minimum or key management are defined). Required: cryptography standard (algorithms, TLS minimum, key management); KMS configuration.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	VR-004; R-005
Related CGI-GAP-001 Category	PR.DS
Related CGI-TPR-001 finding	F-010 (encryption-management CUEC)
Target date	31 Mar 2027

A.8.25

Field	Value
Control	**A.8.25**
Title	Secure development life cycle
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	PR.PS = 0 and CG-02: there is no secure development lifecycle and CGI-POL-007 is unwritten.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: CGI-POL-007 approved; SDLC evidence per release.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	CG-02
Target date	31 Mar 2027

A.8.26

Field	Value
Control	**A.8.26**
Title	Application security requirements
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. No application security requirements are defined for features, including authorisation rules.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: requirements template; sample completed per feature.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.27

Field	Value
Control	**A.8.27**
Title	Secure system architecture and engineering principles
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. No secure architecture principles are documented; concentration on one provider was found only by drawing the dependency graph.
Implementation status	**Not started**
Evidence held or required	Held: CGI-TPR-001 section 2.5 dependency graph. Required: architecture principles; design review records.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004; R-005; VR-002
Related CGI-GAP-001 Category	PR.IR

Field	Value
Related CGI-TPR-001 finding	VR-002 concentration
Target date	31 Dec 2027

A.8.28

Field	Value
Control	**A.8.28**
Title	Secure coding
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	PR.PS = 0 and CG-02: there is no mandatory peer review, no branch protection and no coding standard. This is a brakes control: it stops the authorisation flaw being written in the first place.
Implementation status	**Not started**
Evidence held or required	Held: CGI-POL-002 section 4.5.2 secret scanning (a fragment). Required: coding standard; branch-protection export; review records.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	CG-02
Target date	31 Mar 2027

A.8.29

Field	Value
Control	**A.8.29**
Title	Security testing in development and acceptance
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	PR.PS = 0 and CG-02: no SAST (static application security testing) and no penetration test.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: SAST results in CI; annual penetration test report.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	CG-02
Target date	30 Sep 2027

A.8.30

Field	Value
Control	**A.8.30**
Title	Outsourced development
Theme	Technological
Applicable Y/N	N
Justification for inclusion or exclusion	EXCLUDED. All development is performed by CGI employees (assumption ISO-A02). Re-include before any contractor or agency writes code. Supplier assurance for development tools (CodeCo) is covered by A.5.19 to A.5.22.

Field	Value
Implementation status	**N/A - excluded**
Evidence held or required	Held: n/a. Required: exclusion approved in SoA v1.0.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	N/A - re-evaluate at SoA review 30 Sep 2027

A.8.31

Field	Value
Control	**A.8.31**
Title	Separation of development, test and production environments
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	PR.PS = 0 and CG-02: there is no recorded separation of development, test and production.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: environment diagram; access separation evidence.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004; R-003
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.32

Field	Value
Control	**A.8.32**
Title	Change management
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	PR.PS = 0 and CG-02: there is no change management policy or approval record.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: CGI-POL-007 change section; change records.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-004; R-005
Related CGI-GAP-001 Category	PR.PS
Related CGI-TPR-001 finding	CG-02
Target date	31 Mar 2027

A.8.33

Field	Value
Control	**A.8.33**
Title	Test information
Theme	Technological

Field	Value
Applicable Y/N	Y
Justification for inclusion or exclusion	Missed by CGI-GAP-001. There is no rule preventing production customer data being used in lower environments.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: test-data rule; masked data set evidence.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	R-003; R-004
Related CGI-GAP-001 Category	PR.DS
Related CGI-TPR-001 finding	-
Target date	31 Mar 2027

A.8.34

Field	Value
Control	**A.8.34**
Title	Protection of information systems during audit testing
Theme	Technological
Applicable Y/N	Y
Justification for inclusion or exclusion	No register risk covers this. Included because the ISO-12 internal audit and the REC-16 penetration test will touch production; the rules must exist before either runs.
Implementation status	**Not started**
Evidence held or required	Held: none. Required: audit and test rules of engagement.
Owner (job title)	Chief Technology Officer
Related CGI-RSK-001 v1.1 risk ID	-
Related CGI-GAP-001 Category	-
Related CGI-TPR-001 finding	-
Target date	30 Jun 2027

3.9 Traceability and governance columns

Control	Title	Basis for inclusion	Maturity (0-4)	In CGI-GAP-001 mapping?	CGI-GAP-001 mapped it under	Roadmap link
A.5.1	Policies for information security	Risk + Maturity gap	2	Y	GV.OC; GV.RM; GV.PO	ISO-03; REC-04
A.5.2	Information security roles and responsibilities	Risk + Maturity gap	2	Y	GV.RR	ISO-04
A.5.3	Segregation of duties	Risk + Maturity gap	1	Y	GV.RR	REC-06
A.5.4	Management responsibilities	Risk + Maturity gap	1	Y	GV.OC; GV.RM; GV.RR	REC-04
A.5.5	Contact with authorities	Risk + Maturity gap + Vendor finding	1	Y	RS.CO; RC.CO	ISO-01; REC-14
A.5.6	Contact with special interest groups	Maturity gap	0	Y	RS.CO; RC.CO	REC-12
A.5.7	Threat intelligence	Risk + Maturity gap	0	Y	ID.RA	REC-08
A.5.8	Information security in project management	Risk + Maturity gap + Vendor finding	0	N	-	REC-06
A.5.9	Inventory of information and other associated assets	Risk + Maturity gap + Vendor finding	1	Y	ID.AM	REC-05

Control	Title	Basis for inclusion	Maturity (0-4)	In CGI-GAP-001 mapping?	CGI-GAP-001 mapped it under	Roadmap link
A.5.10	Acceptable use of information and other associated assets	Risk + Maturity gap + Vendor finding	2	Y	ID.AM	REC-04
A.5.11	Return of assets	Risk + Maturity gap + Vendor finding	2	N	-	ISO-11; REC-02
A.5.12	Classification of information	Risk + Maturity gap + Vendor finding	2	Y	ID.AM; PR.DS	REC-05
A.5.13	Labelling of information	Risk + Maturity gap	1	Y	ID.AM	REC-05
A.5.14	Information transfer	Risk + Maturity gap + Vendor finding	2	Y	PR.DS	ISO-09
A.5.15	Access control	Risk + Maturity gap + Vendor finding	2	Y	PR.AA	REC-02
A.5.16	Identity management	Risk + Maturity gap + Vendor finding	2	Y	PR.AA	REC-01; VRA-2026-002 R3
A.5.17	Authentication information	Risk + Maturity gap + Vendor finding	2	Y	PR.AA	REC-01
A.5.18	Access rights	Risk + Maturity gap + Vendor finding	2	Y	PR.AA	REC-02; VRA-2026-001 C1
A.5.19	Information security in supplier relationships	Risk + Maturity gap + Vendor finding	2	Y	GV.SC	REC-15 (delivered)
A.5.20	Addressing information security within supplier agreements	Risk + Maturity gap + Vendor finding	2	Y	GV.SC	ISO-09; VRA-2026-002 R1-R2
A.5.21	Managing information security in the ICT supply chain	Risk + Maturity gap + Vendor finding	2	Y	GV.SC	VRA-2026-001 C2; VRA-2026-002 R6
A.5.22	Monitoring, review and change management of supplier services	Risk + Maturity gap + Vendor finding	2	Y	GV.SC	VRA-2026-001 C2; REC-15
A.5.23	Information security for use of cloud services	Risk + Maturity gap + Vendor finding	1	Y	GV.SC	ISO-02; VRA-2026-001 C1-C4
A.5.24	Information security incident management planning and preparation	Risk + Maturity gap + Vendor finding	2	Y	RS.MA; RS.CO	REC-12
A.5.25	Assessment and decision on information security events	Risk + Maturity gap	1	Y	DE.AE	REC-07
A.5.26	Response to information security incidents	Risk + Maturity gap + Vendor finding	2	Y	RS.MA; RS.MI	REC-12
A.5.27	Learning from information security incidents	Risk + Maturity gap	1	Y	ID.IM; RS.AN	REC-12
A.5.28	Collection of evidence	Risk + Maturity gap + Vendor finding	1	Y	RS.AN	REC-07
A.5.29	Information security during disruption	Risk + Maturity gap + Vendor finding	1	Y	RC.RP; RC.CO	REC-03; REC-14
A.5.30	ICT readiness for business continuity	Risk + Maturity gap + Vendor finding	1	Y	RC.RP	REC-03; VRA-2026-001 C4
A.5.31	Legal, statutory, regulatory and contractual requirements	Risk + Maturity gap + Vendor finding	1	Y	GV.OC	ISO-01
A.5.32	Intellectual property rights	Legal / regulatory - NOT risk-based	0	N	-	ISO-11

Control	Title	Basis for inclusion	Maturity (0-4)	In CGI-GAP-001 mapping?	CGI-GAP-001 mapped it under	Roadmap link
A.5.33	Protection of records	Risk + Maturity gap + Vendor finding	0	N	-	REC-07; ISO-08
A.5.34	Privacy and protection of PII	Risk + Maturity gap + Vendor finding	1	N	-	ISO-09
A.5.35	Independent review of information security	Risk + Maturity gap	0	Y	GV.OV	ISO-12
A.5.36	Compliance with policies, rules and standards for information security	Risk + Maturity gap	1	Y	GV.PO; GV.OV	REC-04; REC-10
A.5.37	Documented operating procedures	Risk + Maturity gap + Vendor finding	1	Y	GV.PO	REC-12
A.6.1	Screening	Risk + Maturity gap	1	N	-	ISO-11
A.6.2	Terms and conditions of employment	Risk + Maturity gap	0	N	-	ISO-11
A.6.3	Information security awareness, education and training	Risk + Maturity gap + Vendor finding	1	Y	PR.AT	REC-09
A.6.4	Disciplinary process	Risk + Maturity gap	0	N	-	ISO-11
A.6.5	Responsibilities after termination or change of employment	Risk + Maturity gap + Vendor finding	1	N	-	ISO-11; REC-02
A.6.6	Confidentiality or non-disclosure agreements	Risk + Maturity gap	0	N	-	ISO-11
A.6.7	Remote working	Risk + Maturity gap	2	N	-	REC-05
A.6.8	Information security event reporting	Risk + Maturity gap + Vendor finding	2	Y	PR.AT; RS.CO	REC-12
A.7.1	Physical security perimeters	Contractual / stakeholder - NOT risk-based	0	N	-	ISO-11
A.7.2	Physical entry	Contractual / stakeholder - NOT risk-based	0	N	-	ISO-11
A.7.3	Securing offices, rooms and facilities	Contractual / stakeholder - NOT risk-based	0	N	-	ISO-11
A.7.4	Physical security monitoring	Excluded	-	N	-	-
A.7.5	Protecting against physical and environmental threats	Contractual / stakeholder - NOT risk-based	0	N	-	ISO-11
A.7.6	Working in secure areas	Excluded	-	N	-	-
A.7.7	Clear desk and clear screen	Contractual / stakeholder - NOT risk-based	2	N	-	ISO-11; REC-04
A.7.8	Equipment siting and protection	Contractual / stakeholder - NOT risk-based	0	N	-	ISO-11
A.7.9	Security of assets off-premises	Maturity gap	1	N	-	REC-05
A.7.10	Storage media	Risk + Maturity gap	2	N	-	-
A.7.11	Supporting utilities	Excluded	-	N	-	-

Control	Title	Basis for inclusion	Maturity (0-4)	In CGI-GAP-001 mapping?	CGI-GAP-001 mapped it under	Roadmap link
A.7.12	Cabling security	Excluded	-	N	-	-
A.7.13	Equipment maintenance	Contractual / stakeholder - NOT risk-based	0	N	-	ISO-11
A.7.14	Secure disposal or re-use of equipment	Maturity gap + Legal	0	N	-	REC-05
A.8.1	User endpoint devices	Risk + Maturity gap	1	Y	ID.AM	REC-05
A.8.2	Privileged access rights	Risk + Maturity gap + Vendor finding	2	Y	PR.AA	REC-02; VRA-2026-001 C1
A.8.3	Information access restriction	Risk + Maturity gap	0	N	-	REC-06; REC-16
A.8.4	Access to source code	Risk + Maturity gap + Vendor finding	0	N	-	REC-06
A.8.5	Secure authentication	Risk + Maturity gap + Vendor finding	2	Y	PR.AA	REC-01
A.8.6	Capacity management	Contractual / stakeholder - NOT risk-based	0	N	-	ISO-11
A.8.7	Protection against malware	Risk + Maturity gap	0	Y	RS.MI	ISO-11
A.8.8	Management of technical vulnerabilities	Risk + Maturity gap + Vendor finding	0	Y	ID.RA; PR.PS	REC-08
A.8.9	Configuration management	Risk + Maturity gap + Vendor finding	0	Y	PR.PS; PR.IR	REC-11
A.8.10	Information deletion	Risk + Maturity gap + Vendor finding	1	Y	PR.DS	REC-17; ISO-08
A.8.11	Data masking	Risk + Maturity gap + Vendor finding	0	Y	PR.DS	ISO-11
A.8.12	Data leakage prevention	Risk + Maturity gap + Vendor finding	0	Y	PR.DS; DE.CM	REC-17
A.8.13	Information backup	Risk + Maturity gap + Vendor finding	1	Y	PR.IR; RC.RP	REC-03
A.8.14	Redundancy of information processing facilities	Risk + Maturity gap + Vendor finding	0	Y	PR.IR	ISO-11
A.8.15	Logging	Risk + Maturity gap + Vendor finding	1	Y	DE.CM; DE.AE; RS.AN	REC-07
A.8.16	Monitoring activities	Risk + Maturity gap + Vendor finding	0	Y	DE.CM; DE.AE	REC-07
A.8.17	Clock synchronization	Risk + Maturity gap	0	N	-	REC-07
A.8.18	Use of privileged utility programs	Risk + Maturity gap	0	N	-	REC-11
A.8.19	Installation of software on operational systems	Risk + Maturity gap	0	N	-	REC-06
A.8.20	Networks security	Risk + Maturity gap	0	Y	PR.IR	REC-11
A.8.21	Security of network services	Risk + Maturity gap	0	N	-	REC-11
A.8.22	Segregation of networks	Risk + Maturity gap	0	Y	PR.IR	REC-18 (split - see RC-04)
A.8.23	Web filtering	Risk + Maturity gap	0	N	-	ISO-11
A.8.24	Use of cryptography	Risk + Maturity gap + Vendor finding	0	Y	PR.DS	ISO-11

Control	Title	Basis for inclusion	Maturity (0-4)	In CGI-GAP-001 mapping?	CGI-GAP-001 mapped it under	Roadmap link
A.8.25	Secure development life cycle	Risk + Maturity gap + Vendor finding	0	Y	PR.PS	REC-06
A.8.26	Application security requirements	Risk + Maturity gap	0	N	-	REC-06
A.8.27	Secure system architecture and engineering principles	Risk + Maturity gap + Vendor finding	0	N	-	REC-18; ISO-02
A.8.28	Secure coding	Risk + Maturity gap + Vendor finding	0	Y	PR.PS	REC-06; REC-16
A.8.29	Security testing in development and acceptance	Risk + Maturity gap + Vendor finding	0	Y	PR.PS	REC-16
A.8.30	Outsourced development	Excluded	-	N	-	-
A.8.31	Separation of development, test and production environments	Risk + Maturity gap	0	Y	PR.PS	REC-06
A.8.32	Change management	Risk + Maturity gap + Vendor finding	0	Y	PR.PS	REC-06
A.8.33	Test information	Risk + Maturity gap	0	N	-	REC-06
A.8.34	Protection of information systems during audit testing	Contractual / stakeholder - NOT risk-based	0	N	-	ISO-12; REC-16

Part 4 — Clauses 4–10 readiness assessment

Scoring: 0 = absent · 1 = partly in place or designed but not evidenced · 2 = met, with evidence. **Gate** marks the requirements whose absence stops a Stage 1 audit regardless of the overall score.

4.1

Field	Value
Clause	**4.1**
Requirement	Understand the organisation and its context: internal and external issues, including whether climate change is relevant (Amd 1:2024)
Stage 1 gate?	N
Score (0-2)	1
Current state	Context exists only as CGI-RSK-001 assumptions A-01 to A-06 (GV.OC = 1).
Gap	No approved context statement; climate change not considered.
Evidence needed	Approved context and issues statement.
Owner (job title)	Chief Executive Officer
Action	ISO-01
Due	31 Oct 2026

4.2

Field	Value
Clause	**4.2**
Requirement	Interested parties, their relevant requirements, and which of those the ISMS addresses
Stage 1 gate?	N
Score (0-2)	1

Field	Value
Current state	Customers, a GDPR supervisory authority and vendors are known across CGI-POL-005 and CGI-TPR-001.
Gap	No interested-parties register; no decision on which requirements the ISMS addresses.
Evidence needed	Interested-parties and obligations register (with A.5.31).
Owner (job title)	Chief Executive Officer
Action	ISO-01
Due	31 Oct 2026

4.3

Field	Value
Clause	**4.3**
Requirement	Determine and document the ISMS scope, considering interfaces and dependencies with other organisations
Stage 1 gate?	Y
Score (0-2)	1
Current state	Drafted in CGI-ISO-001 section 2 (this document).
Gap	Not approved by top management.
Evidence needed	CEO-approved scope statement v1.0.
Owner (job title)	Chief Executive Officer
Action	ISO-02
Due	31 Oct 2026

4.4

Field	Value
Clause	**4.4**
Requirement	Establish, implement, maintain and continually improve the ISMS
Stage 1 gate?	N
Score (0-2)	1
Current state	Components exist (policies, register, gap assessment, vendor programme) but do not run as one system.
Gap	No ISMS manual or process map linking them.
Evidence needed	ISMS overview showing how the clauses 4-10 processes connect.
Owner (job title)	Chief Technology Officer
Action	ISO-08
Due	31 Dec 2026

5.1

Field	Value
Clause	**5.1**
Requirement	Leadership and commitment
Stage 1 gate?	N
Score (0-2)	1
Current state	The CEO approved CGI-POL-001 to -005, CGI-RSK-001, CGI-GAP-001 and CGI-TPR-001.
Gap	The USD 32,100 year-one budget is costed but unapproved (GAP-003); no stated commitment to the ISMS.

Field	Value
Evidence needed	Approved budget; ISMS policy signed by the CEO.
Owner (job title)	Chief Executive Officer
Action	ISO-03
Due	31 Oct 2026

5.2

Field	Value
Clause	**5.2**
Requirement	Information security policy: appropriate, provides a framework for objectives, commits to requirements and continual improvement; documented and communicated
Stage 1 gate?	N
Score (0-2)	1
Current state	Five topic-specific policies are approved.
Gap	No top-level ISMS policy meeting 5.2 a) to d).
Evidence needed	ISMS policy v1.0, communicated and acknowledged.
Owner (job title)	Chief Executive Officer
Action	ISO-03
Due	31 Oct 2026

5.3

Field	Value
Clause	**5.3**
Requirement	Roles, responsibilities and authorities, including for ISMS conformance and reporting to top management
Stage 1 gate?	N
Score (0-2)	1
Current state	Document-level owners exist (GV.RR = 2).
Gap	No one is assigned to ensure ISMS conformance or report its performance.
Evidence needed	Written assignment of an ISMS lead; RACI.
Owner (job title)	Chief Executive Officer
Action	ISO-04
Due	31 Oct 2026

6.1.1

Field	Value
Clause	**6.1.1**
Requirement	Determine risks and opportunities for the ISMS itself and plan actions
Stage 1 gate?	N
Score (0-2)	0
Current state	None.
Gap	ISMS-level risks and opportunities have never been considered (distinct from information security risks).
Evidence needed	Short ISMS risks and opportunities record.
Owner (job title)	Chief Technology Officer
Action	ISO-08

Field	Value
Due	31 Dec 2026

6.1.2

Field	Value
Clause	**6.1.2**
Requirement	Information security risk assessment process, including risk ACCEPTANCE criteria and criteria for performing assessments
Stage 1 gate?	Y
Score (0-2)	1
Current state	CGI-RSK-001 applies a documented NIST SP 800-30 5x5 method and has operated twice (v1.0, v1.1). ID.RA = 3.
Gap	No risk acceptance criteria or appetite (GAP-002), so ACC-001 and ACC-V01 were accepted against nothing. No defined re-assessment cadence.
Evidence needed	CEO-approved risk acceptance criteria; assessment cadence.
Owner (job title)	Chief Executive Officer
Action	ISO-05 (REC-13 pulled forward)
Due	31 Oct 2026

6.1.3

Field	Value
Clause	**6.1.3**
Requirement	Risk treatment: select options, determine controls, compare with Annex A, produce the SoA and a risk treatment plan, and obtain risk owners' approval and residual acceptance
Stage 1 gate?	Y
Score (0-2)	1
Current state	Four treatment options applied; TP-01 to TP-10 costed; SoA drafted here (93 controls).
Gap	SoA and consolidated RTP not approved; residual High risks (R-004, R-005, VR-004) not formally accepted by their owners.
Evidence needed	Approved SoA v1.0; approved RTP; signed residual-risk acceptances.
Owner (job title)	Chief Executive Officer
Action	ISO-06
Due	30 Nov 2026

6.2

Field	Value
Clause	**6.2**
Requirement	Information security objectives: measurable, monitored, communicated; plans to achieve them
Stage 1 gate?	N
Score (0-2)	0
Current state	14 KRIs exist in CGI-RSK-001 v1.1.
Gap	KRIs are indicators, not objectives. No objectives are set.
Evidence needed	Objectives with owners, targets and dates.
Owner (job title)	Chief Technology Officer
Action	ISO-07
Due	30 Nov 2026

6.3

Field	Value
Clause	**6.3**
Requirement	Planning of changes to the ISMS
Stage 1 gate?	N
Score (0-2)	0
Current state	None.
Gap	No rule for making ISMS changes in a planned way.
Evidence needed	Change-planning step in the ISMS procedure.
Owner (job title)	Chief Technology Officer
Action	ISO-08
Due	31 Dec 2026

7.1

Field	Value
Clause	**7.1**
Requirement	Resources
Stage 1 gate?	N
Score (0-2)	1
Current state	The budget is estimated in CGI-RSK-001.
Gap	Not approved; no allocation of staff time to the ISMS.
Evidence needed	Approved budget and time allocation.
Owner (job title)	Chief Executive Officer
Action	ISO-03
Due	31 Oct 2026

7.2

Field	Value
Clause	**7.2**
Requirement	Competence, with documented evidence
Stage 1 gate?	N
Score (0-2)	0
Current state	None on file.
Gap	No competence requirements for ISMS roles and no evidence of competence.
Evidence needed	Role competence matrix; training and certificate records.
Owner (job title)	Head of People and Operations
Action	ISO-10
Due	31 Mar 2027

7.3

Field	Value
Clause	**7.3**
Requirement	Awareness of policy, contribution and implications of non-conformance
Stage 1 gate?	N
Score (0-2)	1

Field	Value
Current state	Induction 60% complete; 60% acknowledgement.
Gap	Not all staff reached; no recurring programme (CG-04).
Evidence needed	100% acknowledgement; REC-09 curriculum records.
Owner (job title)	Head of People and Operations
Action	REC-04; REC-09
Due	31 Mar 2027

7.4

Field	Value
Clause	**7.4**
Requirement	Internal and external communication
Stage 1 gate?	N
Score (0-2)	1
Current state	Policies published; CGI-POL-005 defines incident communications.
Gap	No ISMS communication plan (what, when, with whom, how).
Evidence needed	Communication plan.
Owner (job title)	Chief Technology Officer
Action	ISO-08
Due	31 Dec 2026

7.5

Field	Value
Clause	**7.5**
Requirement	Documented information: creation, updating and control
Stage 1 gate?	N
Score (0-2)	1
Current state	Every CGI policy has a document control block (version, owner, review date).
Gap	No procedure controlling records; no document register.
Evidence needed	Document and record control procedure; ISMS document register.
Owner (job title)	Chief Technology Officer
Action	ISO-08
Due	31 Dec 2026

8.1

Field	Value
Clause	**8.1**
Requirement	Operational planning and control, including control of externally provided processes
Stage 1 gate?	N
Score (0-2)	1
Current state	The CGI-TPR-001 workflow controls externally provided services.
Gap	Other operational processes are not planned or evidenced.
Evidence needed	Operating records for the RTP actions.
Owner (job title)	Chief Technology Officer
Action	ISO-06

Field	Value
Due	31 Mar 2027

8.2

Field	Value
Clause	**8.2**
Requirement	Perform risk assessments at planned intervals or on significant change; retain results
Stage 1 gate?	N
Score (0-2)	2
Current state	Performed September 2026 (v1.0) and again on change (v1.1 vendor addendum); results retained.
Gap	The planned interval is not yet defined (recorded under 6.1.2).
Evidence needed	Next scheduled assessment record.
Owner (job title)	Chief Technology Officer
Action	ISO-05
Due	31 Oct 2026

8.3

Field	Value
Clause	**8.3**
Requirement	Implement the risk treatment plan; retain results
Stage 1 gate?	N
Score (0-2)	1
Current state	CGI-TPR-001 executed (CG-06 closed); AVD-001 and ACC-001 in force.
Gap	Most RTP actions not started (Wave 1 due Q4 2026).
Evidence needed	Treatment status tracker with evidence per action.
Owner (job title)	Chief Technology Officer
Action	ISO-06
Due	31 Mar 2027

9.1

Field	Value
Clause	**9.1**
Requirement	Monitoring, measurement, analysis and evaluation; retain results
Stage 1 gate?	N
Score (0-2)	1
Current state	14 KRIs defined; KRI-V1 measured once (65%).
Gap	No monitoring programme; results not reported (GV.OV = 1).
Evidence needed	Quarterly KRI and objective report.
Owner (job title)	Chief Technology Officer
Action	ISO-07; REC-10
Due	31 Mar 2027

9.2.1

Field	Value
Clause	**9.2.1**

Field	Value
Requirement	Internal audit at planned intervals
Stage 1 gate?	Y
Score (0-2)	0
Current state	None.
Gap	No internal audit has ever been performed. There is no REC for it in CGI-GAP-001 (see RC-03).
Evidence needed	Completed internal audit of all clauses and applicable controls before Stage 1.
Owner (job title)	Chief Executive Officer
Action	ISO-12
Due	31 May 2027

9.2.2

Field	Value
Clause	**9.2.2**
Requirement	Internal audit programme: frequency, methods, responsibilities, criteria and scope; auditor objectivity; results reported
Stage 1 gate?	Y
Score (0-2)	0
Current state	None.
Gap	No programme; no independent auditor identified.
Evidence needed	Audit programme; audit plan; audit report.
Owner (job title)	Chief Executive Officer
Action	ISO-12
Due	31 Mar 2027

9.3.1

Field	Value
Clause	**9.3.1**
Requirement	Management review at planned intervals
Stage 1 gate?	Y
Score (0-2)	0
Current state	None. No security item has appeared on a leadership agenda (GAP-005).
Gap	Never held.
Evidence needed	Minutes of management review #1 (Mar 2027) and #2 (Jun 2027).
Owner (job title)	Chief Executive Officer
Action	ISO-13; REC-10
Due	31 Mar 2027

9.3.2

Field	Value
Clause	**9.3.2**
Requirement	Management review inputs a) to g), including changes in interested parties' needs
Stage 1 gate?	Y
Score (0-2)	0
Current state	None.

Field	Value
Gap	The REC-10 agenda (KRIs, scorecard, TP status) omits several 9.3.2 inputs (see RC-02).
Evidence needed	Agenda template covering 9.3.2 a) to g).
Owner (job title)	Chief Executive Officer
Action	ISO-13
Due	31 Mar 2027

9.3.3

Field	Value
Clause	**9.3.3**
Requirement	Management review results: improvement decisions and changes; documented
Stage 1 gate?	Y
Score (0-2)	0
Current state	None.
Gap	Never held.
Evidence needed	Minutes with decisions and actions.
Owner (job title)	Chief Executive Officer
Action	ISO-13
Due	31 Mar 2027

10.1

Field	Value
Clause	**10.1**
Requirement	Continual improvement
Stage 1 gate?	N
Score (0-2)	1
Current state	Improvement happens through commissioned projects (ID.IM = 1).
Gap	No routine improvement loop.
Evidence needed	Improvement log fed by audits, KRIs, incidents and exceptions.
Owner (job title)	Chief Technology Officer
Action	ISO-08
Due	31 Dec 2026

10.2

Field	Value
Clause	**10.2**
Requirement	Nonconformity and corrective action (correction, root cause, action, effectiveness review); retained
Stage 1 gate?	N
Score (0-2)	0
Current state	CGI-POL-005 section 5.7 covers incident corrective actions only (a fragment).
Gap	No nonconformity process; exceptions (EXC-001 to -003) are not nonconformities.
Evidence needed	NC and corrective action procedure and log.
Owner (job title)	Chief Technology Officer
Action	ISO-08
Due	31 Dec 2026

Result: 19 of 56 points = 33.9%. Distribution: 1 requirement met, 17 partial, 10 absent. **The only fully met requirement is 8.2 (risk assessment performed and retained)**, the clause-level twin of ID.RA = 3. **Every Stage 1 gate fails:** 4.3, 6.1.2, 6.1.3, 9.2.1, 9.2.2, 9.3.1, 9.3.2, 9.3.3.

The finding that matters most is in 6.1.2. Clause 6.1.2 a) requires risk **acceptance criteria**. CGI-GAP-001 found there is no risk appetite (GAP-002) and scheduled the fix (REC-13) for Q2 2027. Under ISO 27001 that is too late: without acceptance criteria, **no residual risk can be validly accepted, so the SoA and the risk treatment plan cannot be approved.** This is conflict RC-01, resolved in Part 7.

Part 5 — Mandatory documented information checklist

Ref	Documented information	Required by	Status	What Cypher Group Inc. already has	What is missing	Owner (job title)	Due
DI-01	ISMS scope	Clause 4.3	**Partial**	CGI-ISO-001 section 2 (draft)	CEO approval	Chief Executive Officer	31 Oct 2026
DI-02	Information security policy	Clause 5.2	**Missing**	None at ISMS level (CGI-POL-001 to -005 are topic-specific)	Top-level ISMS policy	Chief Executive Officer	31 Oct 2026
DI-03	Risk assessment process, including acceptance criteria	Clause 6.1.2	**Partial**	CGI-RSK-001 methodology and thresholds	Risk acceptance criteria and appetite (GAP-002)	Chief Executive Officer	31 Oct 2026
DI-04	Risk treatment process	Clause 6.1.3	**Partial**	CGI-RSK-001 treatment strategies (Mitigate, Transfer, Accept, Avoid)	Link to SoA and residual-acceptance step	Chief Technology Officer	30 Nov 2026
DI-05	Statement of Applicability	Clause 6.1.3 d)	**Partial**	CGI-ISO-001 section 3 (draft v1.0, 93 controls)	CEO approval	Chief Executive Officer	30 Nov 2026
DI-06	Risk treatment plan	Clause 6.1.3 e); 8.3	**Partial**	CGI-RSK-001 TP-01 to TP-10; CGI-GAP-001 REC-01 to REC-18; CGI-TPR-001 R1-R8 and C1-C4; CGI-ISO-001 section 7	One consolidated plan approved by the risk owners	Chief Executive Officer	30 Nov 2026
DI-07	Information security objectives	Clause 6.2	**Missing**	None (the KRIs are inputs)	Objectives with measures and dates	Chief Technology Officer	30 Nov 2026
DI-08	Evidence of competence	Clause 7.2 d)	**Missing**	None	Competence matrix and records	Head of People and Operations	31 Mar 2027
DI-09	Documented information the organisation decides is necessary	Clause 7.5.1 b)	**Partial**	CGI policy document control blocks	Document register and control procedure	Chief Technology Officer	31 Dec 2026
DI-10	Operational planning and control records	Clause 8.1	**Partial**	CGI-TPR-001 workflow and records	Records for the other RTP processes	Chief Technology Officer	31 Mar 2027
DI-11	Results of risk assessments	Clause 8.2	**Have**	CGI-RSK-001 v1.0 and v1.1 (VR-001 to VR-009 addendum)	Next scheduled run	Chief Technology Officer	31 Oct 2026

Ref	Documented information	Required by	Status	What Cypher Group Inc. already has	What is missing	Owner (job title)	Due
DI-12	Results of risk treatment	Clause 8.3	**Partial**	CGI-TPR-001 (CG-06 closed); ACC-001; ACC-V01; AVD-001	Evidence for each RTP action	Chief Technology Officer	31 Mar 2027
DI-13	Monitoring and measurement results	Clause 9.1	**Partial**	KRI-V1 measured once (65%)	Quarterly results for all KRIs and objectives	Chief Technology Officer	31 Mar 2027
DI-14	Audit programme and audit results	Clause 9.2.2	**Missing**	None	Programme, plan and report	Chief Executive Officer	31 May 2027
DI-15	Management review results	Clause 9.3.3	**Missing**	None	Minutes of two reviews before Stage 1	Chief Executive Officer	30 Jun 2027
DI-16	Nonconformities, actions taken and corrective action results	Clause 10.2	**Missing**	None (EXC register is not an NC log)	NC and corrective action log	Chief Technology Officer	31 Dec 2026
DI-17	Topic-specific policies	A.5.1	**Partial**	CGI-POL-001 to -005	CGI-POL-006 Backup, -007 Secure Development, -008 Vulnerability Management; cryptography standard	Chief Technology Officer	31 Mar 2027
DI-18	Inventory of information and other associated assets	A.5.9	**Partial**	CGI-TPR-001 vendor inventory (17)	Asset and SaaS inventory (REC-05)	IT Operations Manager	31 Mar 2027
DI-19	Rules for acceptable use	A.5.10 (control text says documented)	**Have**	CGI-POL-001 v1.0	Acknowledgement to 100%	Head of People and Operations	31 Dec 2026
DI-20	Legal, statutory, regulatory and contractual requirements	A.5.31 (control text says documented)	**Missing**	None	Obligations register	Chief Executive Officer	31 Oct 2026
DI-21	Documented operating procedures	A.5.37 (control text says documented)	**Missing**	None beneath the policies	Runbooks (REC-12)	IT Operations Manager	30 Jun 2027
DI-22	Confidentiality or non-disclosure agreements	A.6.6 (control text says documented)	**Missing**	None on file	Signed NDAs	Head of People and Operations	31 Dec 2026
DI-23	Configurations, including security configurations	A.8.9 (control text says documented)	**Missing**	None	CIS-based baseline (REC-11)	IT Operations Manager	30 Jun 2027
DI-24	Incident management plan and procedures	A.5.24 / A.5.26 (auditor-expected)	**Have**	CGI-POL-005 v1.0	Exercise record; runbooks	Chief Technology Officer	30 Jun 2027
DI-25	ICT continuity plan with RTO and RPO	A.5.30 (auditor-expected)	**Missing**	None	CGI-POL-006 and restore test (REC-03)	IT Operations Manager	15 Dec 2026
DI-26	Supplier security procedure and supplier register	A.5.19 to A.5.22 (auditor-expected)	**Have**	CGI-TPR-001 v1.0; CGI-TPR-002	Review records on cadence	Chief Technology Officer	30 Sep 2027
DI-27	Record of processing activities	GDPR Art. 30 (legal, via A.5.34)	**Missing**	None (out of scope in CGI-GAP-001)	Article 30 record	Chief Technology Officer	31 Dec 2026

Result: 4 Have · 11 Partial · 12 Missing (of 27). Projects 1–4 supplied the risk results (DI-11), the acceptable use rules (DI-19), the incident plan (DI-24) and the supplier procedure (DI-26). What is missing is almost entirely **the management system around them**: the ISMS policy, objectives, competence, internal audit, management review and nonconformity records.

Part 6 — Certification readiness score

6.1 The method (published before scoring)

Element	Rule	Why
Clause score (weight **60%**)	Sum of the 0–2 scores across the 28 requirements in Part 4, divided by 56	Clauses cannot be excluded, and at a first certification they are where most major nonconformities arise
Annex A score (weight **40%**)	Implemented = 1, Partial = 0.5, Not started = 0, averaged over applicable controls	Annex A controls may legitimately be partial under a dated risk treatment plan
Gate override	**If any gate requirement (4.3, 6.1.2, 6.1.3, 9.2.1, 9.2.2, 9.3.1, 9.3.2, 9.3.3) is not fully met, the answer is NO-GO whatever the percentage**	A certification body will not proceed without a scope, acceptance criteria, an SoA, an internal audit or a management review. Same idea as the CGI-TPR-001 veto: a score without a veto can be gamed by breadth
Bands	≥ 85% and no gate failure = Ready for Stage 1 · 60–84% = Ready within 90 days · < 60% = Not ready	

6.2 The score

Component	Calculation	Result
Clauses 4–10	19 ÷ 56	**33.9%**
Annex A	(0 × 1 + 45 × 0.5) ÷ 88	**25.6%**
Weighted readiness	0.6 × 33.9% + 0.4 × 25.6%	**30.6% — Not ready**
Gate failures	8 of 8	**NO-GO**

6.3 Go / no-go on a Stage 1 audit today

NO-GO. A Stage 1 auditor would find no approved scope, no risk acceptance criteria, no approved SoA, no internal audit and no management review. Each of these alone would stop Stage 2 from being scheduled. Booking Stage 1 now would buy an expensive list of things this document already contains.

6.4 Realistic certification date: November 2027

Constraint	Earliest it can be met	Reason
Foundation documents approved (ISO-01 to ISO-06)	Nov 2026	Staff time only; one CEO sign-off cycle
Code-path controls operating (REC-06, REC-08)	From Q1 2027, with two quarters of evidence by Q3 2027	An auditor samples operation over time, not a policy dated last week
Internal audit completed (ISO-12)	May 2027	Needs the controls to exist before they can be audited
Two management reviews (ISO-13)	Mar and Jun 2027	The second must consider the internal audit results
Stage 1	**Jul 2027**	After the internal audit and review #2
Corrective actions (ISO-15)	Aug 2027	Time to close Stage 1 concerns
Tier 1 vendor re-reviews (A.5.22 operating evidence)	Sep 2027	The first point at which the supplier cycle has actually run
Stage 2	**Oct 2027**	After both of the above

Constraint	Earliest it can be met	Reason
Certificate issued	**Nov 2027**	CB technical review and decision, assuming minor nonconformities only

This date falls inside CGI-GAP-001's declared Q4 2027 target state and inside its stated 18-month ISO destination (section 1.2; 18 months from September 2026 is March 2028).

An aggressive alternative exists: Stage 1 in April 2027 and Stage 2 in June 2027, if REC-06 and REC-08 land by December 2026 and the internal audit runs in March. It is **not recommended**. The supplier controls would have almost no operating history, R-004 and R-005 would be sampled with barely one quarter of evidence, and a major nonconformity costs more time than it saves.

Part 7 — Prioritised roadmap to certification

7.1 Certification actions (ISO-01 to ISO-17)

ISO-01

Field	Value
ID	ISO-01
Action	Context, interested parties and obligations register (including the climate-change relevance decision)
Clause / control	4.1; 4.2; A.5.31
Owner (job title)	Chief Executive Officer
Start	01 Oct 2026
Due	31 Oct 2026
Phase	Phase 0 - Foundation
Est. cost (USD)	0
Dependency	None
Notes	Would support GV.OC 1 -> 2 once approved

ISO-02

Field	Value
ID	ISO-02
Action	Approve the ISMS scope and boundary, including the CloudCo shared-responsibility statement
Clause / control	4.3; A.5.23; A.8.27
Owner (job title)	Chief Executive Officer
Start	01 Oct 2026
Due	31 Oct 2026
Phase	Phase 0 - Foundation
Est. cost (USD)	0
Dependency	ISO-01
Notes	Takes the documentation half of REC-18 forward (RC-04)

ISO-03

Field	Value
ID	ISO-03
Action	ISMS policy v1.0; approve the USD 32,100 year-one budget and ISMS time allocation

Field	Value
Clause / control	5.1; 5.2; 7.1
Owner (job title)	Chief Executive Officer
Start	01 Oct 2026
Due	31 Oct 2026
Phase	Phase 0 - Foundation
Est. cost (USD)	0
Dependency	ISO-01
Notes	One page, signed by the CEO

ISO-04

Field	Value
ID	ISO-04
Action	Assign the ISMS lead (CTO) and publish the ISMS RACI
Clause / control	5.3; A.5.2
Owner (job title)	Chief Executive Officer
Start	01 Oct 2026
Due	31 Oct 2026
Phase	Phase 0 - Foundation
Est. cost (USD)	0
Dependency	None
Notes	Implements the GAP-003 recommended action

ISO-05

Field	Value
ID	ISO-05
Action	Risk acceptance criteria and appetite; annual plus event-driven assessment cadence
Clause / control	6.1.2; 8.2
Owner (job title)	Chief Executive Officer
Start	01 Oct 2026
Due	31 Oct 2026
Phase	Phase 0 - Foundation
Est. cost (USD)	0
Dependency	None
Notes	Same work as REC-13, pulled forward from Q2 2027 (RC-01)

ISO-06

Field	Value
ID	ISO-06
Action	Approve SoA v1.0 and one consolidated risk treatment plan; risk owners sign residual acceptance for R-004, R-005 and VR-004
Clause / control	6.1.3; 8.1; 8.3
Owner (job title)	Chief Executive Officer
Start	01 Nov 2026
Due	30 Nov 2026

Field	Value
Phase	Phase 1 - Plan
Est. cost (USD)	0
Dependency	ISO-05
Notes	Without ISO-05 these acceptances have no criteria to be made against

ISO-07

Field	Value
ID	ISO-07
Action	ISMS objectives and measurement plan built on the 14 KRIs
Clause / control	6.2; 9.1
Owner (job title)	Chief Technology Officer
Start	01 Nov 2026
Due	30 Nov 2026
Phase	Phase 1 - Plan
Est. cost (USD)	0
Dependency	ISO-06
Notes	Example objective: KRI-V1 (DPA coverage) at 100% and held there every quarter

ISO-08

Field	Value
ID	ISO-08
Action	ISMS procedures: document and record control, change planning, communication, ISMS risks and opportunities, NC and corrective action, improvement log
Clause / control	4.4; 6.1.1; 6.3; 7.4; 7.5; 10.1; 10.2
Owner (job title)	Chief Technology Officer
Start	01 Nov 2026
Due	31 Dec 2026
Phase	Phase 1 - Plan
Est. cost (USD)	0
Dependency	ISO-03
Notes	One short procedure document

ISO-09

Field	Value
ID	ISO-09
Action	Execute the six outstanding DPAs; approve the CGI-POL-004 section 4.2 amendment; build the GDPR Art. 30 record of processing
Clause / control	A.5.14; A.5.20; A.5.34
Owner (job title)	Chief Technology Officer
Start	01 Oct 2026
Due	31 Dec 2026
Phase	Phase 1 - Plan
Est. cost (USD)	0
Dependency	None
Notes	DPAs by 31 Oct 2026 (CGI-TPR-001 30-day ask); record of processing by 31 Dec 2026

ISO-10

Field	Value
ID	ISO-10
Action	Competence matrix and records; CTO completes ISO/IEC 27001 Lead Implementer training
Clause / control	7.2
Owner (job title)	Head of People and Operations
Start	01 Jan 2027
Due	31 Mar 2027
Phase	Phase 2 - Build
Est. cost (USD)	2,500
Dependency	ISO-04
Notes	Training cost is a planning estimate

ISO-11

Field	Value
ID	ISO-11
Action	People, physical and residual technical baseline: screening, terms, disciplinary, NDAs, office rules, malware, masking, web filtering, cryptography, capacity, licences, audit-testing rules
Clause / control	A.6.1-A.6.6; A.7.x; A.8.6; A.8.7; A.8.11; A.8.14; A.8.23; A.8.24; A.5.32; A.8.34
Owner (job title)	Head of People and Operations
Start	01 Jan 2027
Due	30 Jun 2027
Phase	Phase 2 - Build
Est. cost (USD)	0
Dependency	ISO-03
Notes	Staff time; owners per SoA row

ISO-12

Field	Value
ID	ISO-12
Action	Internal audit programme; independent internal audit of clauses 4-10 and all applicable controls
Clause / control	9.2; A.5.35
Owner (job title)	Chief Executive Officer
Start	01 Mar 2027
Due	31 May 2027
Phase	Phase 3 - Check
Est. cost (USD)	6,000
Dependency	ISO-06
Notes	Planning estimate for ~4-5 external auditor days; auditor must not audit their own work

ISO-13

Field	Value
ID	ISO-13
Action	Management review #1 (Mar 2027) and #2 (Jun 2027, after the internal audit), using the REC-10 forum with the full 9.3.2 agenda

Field	Value
Clause / control	9.3
Owner (job title)	Chief Executive Officer
Start	01 Mar 2027
Due	30 Jun 2027
Phase	Phase 3 - Check
Est. cost (USD)	0
Dependency	ISO-07; ISO-12
Notes	Same forum as REC-10, with an extended agenda (RC-02)

ISO-14

Field	Value
ID	ISO-14
Action	Select an accredited certification body (check the DAkkS/UKAS mark and scope); fix audit days; book Stage 1 and Stage 2
Clause / control	Certification
Owner (job title)	Chief Executive Officer
Start	01 Jan 2027
Due	31 Mar 2027
Phase	Phase 2 - Build
Est. cost (USD)	0
Dependency	ISO-02
Notes	Selection itself is free; fees in ISO-17

ISO-15

Field	Value
ID	ISO-15
Action	Corrective actions from the internal audit and Stage 1
Clause / control	10.2
Owner (job title)	Chief Technology Officer
Start	01 Jun 2027
Due	31 Aug 2027
Phase	Phase 4 - Audit
Est. cost (USD)	0
Dependency	ISO-12
Notes	Staff time

ISO-16

Field	Value
ID	ISO-16
Action	Purchase ISO/IEC 27001:2022 (+Amd 1) and ISO/IEC 27002:2022
Clause / control	Support
Owner (job title)	Chief Technology Officer
Start	01 Oct 2026
Due	15 Oct 2026

Field	Value
Phase	Phase 0 - Foundation
Est. cost (USD)	400
Dependency	None
Notes	Planning estimate

ISO-17

Field	Value
ID	ISO-17
Action	Certification audit: Stage 1 (Jul 2027) and Stage 2 (Oct 2027, after the Tier 1 vendor re-reviews due Sep 2027)
Clause / control	Certification
Owner (job title)	Chief Executive Officer
Start	01 Jul 2027
Due	31 Oct 2027
Phase	Phase 4 - Audit
Est. cost (USD)	14,000
Dependency	ISO-12; ISO-13; ISO-14
Notes	Planning estimate for a 50-person single-site scope; certificate expected Nov 2027

Field	Value
ID	-
Action	**Total ISO-specific cost (planning estimate)**
Clause / control	-
Owner (job title)	-
Start	-
Due	-
Phase	-
Est. cost (USD)	**22,900**
Dependency	-
Notes	-

Costs (planning estimates, ISO-A05):

- **ISO-specific cost to certificate: USD 22,900.** Surveillance audits: about USD 7,000 a year from 2028.
- **The whole programme to certificate: USD 55,000.** That is the USD 32,100 year-one budget already costed in CGI-RSK-001 (which absorbs the ~USD 3,600 ChatCo uplift from CGI-TPR-001), plus the ISO costs. It equals **1.5% of ~USD 3.6M ARR**.

7.2 Sequence

Phase	Window	Actions	CGI-GAP-001 wave running alongside
0 — Foundation	Oct 2026	ISO-01 to ISO-05, ISO-09 (DPAs), ISO-16	Wave 1 (REC-01 to REC-04)
1 — Plan	Nov–Dec 2026	ISO-06 to ISO-09	Wave 1 completes; ChatCo and CloudCo conditions due 15 Dec 2026
2 — Build	Q1 2027	ISO-10, ISO-11, ISO-14; management review #1	**Wave 2 (REC-05 to REC-10). REC-06 is immovable**

Phase	Window	Actions	CGI-GAP-001 wave running alongside
3 — Check	Q2 2027	ISO-12 internal audit (May); management review #2 (Jun)	Wave 3 (REC-11, -12, -14); REC-13 already done; REC-15 delivered
4 — Audit	Q3–Q4 2027	ISO-15, ISO-17: Stage 1 Jul, Stage 2 Oct, certificate Nov	Wave 4 (REC-16 in Aug, REC-17, REC-18 remediation)

7.3 Reconciliation with CGI-GAP-001 REC-01 to REC-18

REC	Recommendation (CGI-GAP-001)	GAP quarter	ISO clause / control served	Latest date ISO needs it	Conflict?	Resolution
REC-01	MFA to 100%; retire ACC-001	Q4 2026	A.5.17; A.8.5	Before Stage 1	No	Keep.
REC-02	First quarterly privileged access review	Q4 2026	A.5.18; A.8.2	4 quarterly records by Stage 2	No	Keep; the Dec 2026, Mar, Jun and Sep 2027 reviews give four samples.
REC-03	Restore test; CGI-POL-006 with RTO/RPO	Q4 2026	A.8.13; A.5.30	Before Stage 1	No	Keep; same work as VRA-2026-001 C4 (15 Dec 2026) - do not run it twice.
REC-04	Acknowledgement 60% -> 100%; joiner gate	Q4 2026	A.5.1; A.5.4; 7.3	Before Stage 1	No	Keep.
REC-05	Asset and SaaS inventory	Q1 2027	A.5.9; A.5.12; A.5.13; A.8.1	Before Stage 1	No	Keep. Note: REC-15 was delivered before its REC-05 dependency; the vendor inventory is an input, not a substitute.
REC-06	CGI-POL-007; branch protection with peer review	Q1 2027	A.8.25; A.8.28; A.8.31; A.8.32; A.8.3; A.8.4	Operating for 2+ quarters before Stage 2	No - but a hard deadline	Keep Q1 2027 and treat it as immovable: any slip moves the certificate date.
REC-07	CloudTrail, central logs, alerting	Q1 2027	A.8.15; A.8.16; A.8.17; A.5.28	Before Stage 1	No	Keep.
REC-08	CGI-POL-008; authenticated scanning	Q1 2027	A.8.8; A.5.7	Operating for 2+ quarters before Stage 2	No	Keep.
REC-09	Awareness curriculum; phishing simulation	Q1 2027	A.6.3; 7.3	Before Stage 1	No	Keep.
REC-10	Quarterly security review with the CEO	Q1 2027	9.3; 9.1	MR #1 by Mar 2027	PARTIAL (RC-02)	The REC-10 agenda (KRIs, scorecard, TP status) is not a full clause 9.3 review. Extend it to the 9.3.2 a) to g) inputs and minute it as the management review.
REC-11	CIS AWS baseline; posture monitoring	Q2 2027	A.8.9; A.8.20; A.8.21	Before Stage 2	No - tight	Keep Q2 2027; it gives only one quarter of evidence before Stage 2. Start in April, not June.
REC-12	SEV1 tabletop; lessons learned	Q2 2027	A.5.24; A.5.26; A.5.27; A.6.8	Before Stage 1	No	Keep; schedule the tabletop in April 2027 so lessons feed MR #2.
REC-13	Risk appetite; assessment cadence	Q2 2027	6.1.2 a) acceptance criteria	Before SoA and RTP approval (Nov 2026)	YES (RC-01)	Pull forward to 31 Oct 2026 as ISO-05. Remove the REC-10 dependency: the CEO approves directly, and the approval is ratified at MR #1.
REC-14	Customer recovery communication pack; status page	Q2 2027	A.5.29; A.5.5	Before Stage 2	No	Keep; CGI-VEN-017 onboarding under way.

REC	Recommendation (CGI-GAP-001)	GAP quarter	ISO clause / control served	Latest date ISO needs it	Conflict?	Resolution
REC-15	Tiered vendor inventory; DPAs; section 4.2 amendment	Q2 2027	A.5.19 to A.5.23	Delivered	STATUS CHANGE (RC-05)	Delivered 15 Sep 2026 by CGI-TPR-001, three quarters early. The outstanding DPAs and section 4.2 approval move to ISO-09.
REC-16	SAST in CI; annual penetration test	Q3 2027	A.8.29; A.8.3	RTP-dated at Stage 2 is acceptable	No	Keep; run the test in Aug 2027 so the report is available at Stage 2.
REC-17	Data egress and DLP monitoring	Q3 2027	A.8.12; A.8.10	RTP-dated at Stage 2 is acceptable	No	Keep.
REC-18	Segmentation; production boundary; shared-responsibility boundary	Q4 2027	A.8.22; A.8.27; A.5.23	Boundary needed for scope (Oct 2026)	YES (RC-04)	Split: the shared-responsibility boundary moves to ISO-02 (Oct 2026); segmentation remediation stays in Q4 2027 in the RTP, with R-005 residual accepted under ISO-05.

7.4 Conflicts stated explicitly

ID	Conflict	Why it matters	Resolution
RC-01	REC-13 (Q2 2027) versus clause 6.1.2 a)	Risk acceptance criteria are a prerequisite of the SoA and RTP approval, not a Q2 2027 improvement.	REC-13 becomes ISO-05, due 31 Oct 2026.
RC-02	REC-10 versus clause 9.3.2	A quarterly security review is not automatically a management review.	Extend the agenda to inputs a) to g); minute it as the management review (ISO-13).
RC-03	No internal audit anywhere in REC-01 to REC-18	An omission in CGI-GAP-001, not a contradiction. Clause 9.2 cannot be excluded.	New action ISO-12.
RC-04	REC-18 (Q4 2027) falls after Stage 2	The scope statement needs the CloudCo boundary now.	Split: documentation to ISO-02 (Oct 2026); segmentation remains Q4 2027 in the RTP.
RC-05	REC-15 shows Q2 2027 but was delivered Sep 2026	A stale status, not a contradiction.	Mark delivered; leftovers to ISO-09.
RC-06	Which control-gap ID sits behind PR.PS	Citing the wrong gap ID breaks the trace from the SoA back to the register.	CGI-RSK-001 section 4.3: CG-02 is secure development and vulnerability management, CG-04 is awareness training. CG-02 is used throughout this document.

Part 8 — One-page executive summary

> **To:** Jerry Gold, Chief Executive Officer · **From:** O.S, Assessor · **Date:** 16 September 2026 **Subject:** Can we get ISO 27001 certified, and when?

Answer: yes, in November 2027, not sooner. Booking an audit today would fail.

Where we stand.

- **88 of 93 ISO controls apply to us.** We have excluded 5 because we run no data centre or server room and outsource no development.
- **None is yet running to an auditable standard; 45 are partly in place.**
- **Readiness is 30.6%.** The rules that decide certification (scope, risk acceptance, internal audit, management review) have never been done.

The three things that matter.

1. **We have policies but not a management system.** An auditor checks that we set objectives, audit ourselves and review results at leadership level. We have never done any of these. They are cheap and they are yours: one policy signature, one risk-appetite decision, two minuted reviews.
2. **Our code path is unprotected.** Eleven controls on the code path behind R-004 (the API authorisation flaw) are all Not started. The secure development policy and branch protection (REC-06) must be live by March 2027. **If that slips, the certificate slips.**
3. **Six vendors still have no data processing agreement.** That is a GDPR gap today and the most likely serious audit finding. **Signatures by 31 October 2026.**

What I need from you in October 2026: approve the scope, the ISMS policy, the year-one budget and a risk appetite. The appetite moves forward from Q2 2027, because nothing can be formally accepted without it.

Cost: about **USD 22,900** for certification on top of the USD 32,100 already costed: **USD 55,000 in total, 1.5% of ARR**.

What it buys: a certificate enterprise buyers accept without a 300-question questionnaire, covering the platform they are actually buying.

Part 9 — Effect on the CGI-GAP-001 maturity score

The overall score does not move: it stays at 1.32 / 4.00 (29 ÷ 22). No Category moves.

An SoA is a **map of the gaps, not the closure of any**. It describes 93 controls and implements none. The same restraint as Project 4 applies: **a prerequisite is not a score, and an approved but unevidenced control is a 2.**

- **GV.OC stays 1.** A scope statement and context are drafted, not approved. When ISO-01 and ISO-02 are CEO-approved (Oct 2026), GV.OC can move to 2. The overall score would then be **30/22 = 1.36**.
- **GV.RM stays 2.** The fix for its gap (risk appetite) is scheduled, not done. It reaches 3 only when the cadence has run.
- **GV.PO stays 2.** No ISMS policy exists yet.
- **GV.OV stays 1.** No independent review and no management review have happened.
- **GV.SC stays 2.** Section 3.5 explains why this is not a 3.
- **ID.RA stays 3,** and this document does not raise it: its Annex A mappings are Not started.

Ref	Category	Name	v1.0 (15 Sep)	After Project 4	After Project 5	Target	Moved?
GAP-001	GV.OC	Organizational Context	1	1	1	2	No
GAP-002	GV.RM	Risk Management Strategy	2	2	2	3	No
GAP-003	GV.RR	Roles, Responsibilities and Authorities	2	2	2	3	No
GAP-004	GV.PO	Policy	2	2	2	3	No
GAP-005	GV.OV	Oversight	1	1	1	3	No
GAP-006	GV.SC	Cybersecurity Supply Chain Risk Management	0	2	2	2	0 -> 2 (Project 4)
GAP-007	ID.AM	Asset Management	1	1	1	3	No
GAP-008	ID.RA	Risk Assessment	3	3	3	3	No
GAP-009	ID.IM	Improvement	1	1	1	2	No
GAP-010	PR.AA	Identity Management, Authentication and Access Control	2	2	2	3	No
GAP-011	PR.AT	Awareness and Training	1	1	1	3	No
GAP-012	PR.DS	Data Security	2	2	2	3	No
GAP-013	PR.PS	Platform Security	0	0	0	3	No

Ref	Category	Name	v1.0 (15 Sep)	After Project 4	After Project 5	Target	Moved?
GAP-014	PR.IR	Technology Infrastructure Resilience	0	0	0	3	No
GAP-015	DE.CM	Continuous Monitoring	1	1	1	3	No
GAP-016	DE.AE	Adverse Event Analysis	1	1	1	2	No
GAP-017	RS.MA	Incident Management	2	2	2	3	No
GAP-018	RS.AN	Incident Analysis	1	1	1	2	No
GAP-019	RS.CO	Incident Response Reporting and Communication	2	2	2	3	No
GAP-020	RS.MI	Incident Mitigation	1	1	1	2	No
GAP-021	RC.RP	Incident Recovery Plan Execution	1	1	1	3	No
GAP-022	RC.CO	Incident Recovery Communication	0	0	0	2	No
	OVERALL		**27/22 = 1.23**	**29/22 = 1.32**	**29/22 = 1.32**	**59/22 = 2.68**	

Appendix A — Verification, assumptions and limitations

A.1 Verification performed (in code, not by eye)

Check	Result
93 controls, one row each, in standard order; themes 37 / 8 / 14 / 34	Pass
Applicable + excluded = 93	Pass: 88 + 5
Implemented + Partial + Not started = applicable	Pass: 0 + 45 + 43 = 88
Every applicable control traced to a risk, a Category or a vendor finding, or explicitly marked not risk-based	Pass: 75 risk-based; 3 Category-only; 10 not risk-based
Every risk ID valid (R-001 to R-005, VR-001 to VR-009), and all 14 referenced at least once	Pass
Every CGI-TPR-001 finding F-001 to F-013 and O-001 referenced at least once	Pass
No control maturity above the highest current score of its related Categories	Pass
Every control CGI-GAP-001 mapped keeps at least one of its mapping Categories	Pass: 55 mapped, 38 missed
A.5.7, A.8.8, A.8.25, A.8.28, A.8.29, A.8.31, A.8.32 = Not started (PR.PS = 0)	Pass
A.5.19 to A.5.23 not Implemented (GV.SC = 2)	Pass
No excluded control appears in the CGI-GAP-001 mappings	Pass
Every control the CGI-POL pack maps in its own framework tables (38) is credited or named as a fragment	Pass
Every owner is a job title; every target date is after 16 Sep 2026	Pass
Clause score 19/56; Annex A 22.5/88; weighted 30.6%	Recomputed in code and as workbook formulas
CGI-GAP-001 sums 27 → 29 → 29 (target 59); averages 1.23 → 1.32 → 1.32 (target 2.68)	Pass
CGI-RSK-001 v1.1: 213 inherent, 122 residual, 43% reduction, mean residual 8.71	Pass (unchanged by this project)
REC-01 to REC-18 all reconciled	Pass: 18 of 18
ISO cost total USD 22,900; programme USD 55,000; 1.5% of ARR	Pass

Check	Result
Workbook recalculated in LibreOffice with zero formula errors; workbook totals re-read and matched to the code values	Pass: 13 sheets, 568 formulas, 0 errors (`11_Issue_Checklist` shows 18 of 18 PASS)

A.2 Assumptions

ID	Assumption	Why it matters
ISO-A01	Cypher Group Inc. operates from a single head office. Its address is not defined in Projects 1-4, so the certificate line carries a bracketed address field.	Projects 1-4 never state a location; a real certificate must.
ISO-A02	All software development is performed by CGI employees; no contractor or agency writes code.	Basis for excluding A.8.30. Re-include before any outsourcing.
ISO-A03	The head office is a leased serviced office whose landlord operates building entry control and fire safety; there is no server or network room.	Basis for excluding A.7.4, A.7.6, A.7.11 and A.7.12.
ISO-A04	Customers depend on platform availability commercially; no contractual SLA figure is recorded in Projects 1-4.	Basis for including A.8.6 on a stakeholder rather than a risk basis.
ISO-A05	ISO-specific costs are planning estimates for a 50-person single-site scope, not quotes.	Obtain three certification-body quotes in ISO-14.
ISO-A06	The Project 4 approval of CGI-TPR-001 by the CEO is treated as the approval of the supplier procedure.	Required for GV.SC = 2 and for A.5.19 to A.5.22 at maturity 2.

A.3 Limitations

- This is a **documentation readiness review**. No control was technically tested, and "Not started" means that no evidence was produced.
- Maturity scores are assessor judgements on the CGI-GAP-001 scale. A second assessor could differ by one level on individual controls; the consistency rule in section 3.1 bounds that.
- ISO/IEC 27001 and 27002 wording is **paraphrased**. The standards are copyrighted and must be purchased (ISO-16).
- Certification-body behaviour (audit days, timelines, grading) varies. The dates and costs are planning estimates to validate with three quotes.

Appendix B — Glossary

Term	Definition
AB	Accreditation body. Accredits certification bodies (DAkkS, UKAS, ANAB)
Amd 1:2024	Amendment to ISO/IEC 27001:2022 adding climate-change consideration to clauses 4.1 and 4.2
Annex A	The 93 reference controls in ISO/IEC 27001:2022, grouped into four themes
Applicable	The organisation's risks or obligations need the control. Separate from whether it is implemented
CB	Certification body. Audits the organisation and issues the certificate
CG-01 to CG-06	CGI-RSK-001 control gaps: backup · secure development and vulnerability management · cloud configuration · awareness · DLP · third-party assurance (closed)
CR-01 to CR-03	Candidate risks proposed for the next CGI-RSK-001 review; not register entries
CUEC	Complementary User Entity Control. A control a SOC 2 report assumes the customer performs
DPA	Data Processing Agreement (GDPR Article 28)
Gate	A clause requirement whose absence makes a Stage 1 audit a no-go regardless of score
IAF	International Accreditation Forum; publishes IAF CertSearch
ISMS	Information Security Management System
ISO / IEC	International Organization for Standardization / International Electrotechnical Commission

Term	Definition
ISO-01 to ISO-17	Certification roadmap actions in this document
Major / minor NC	Nonconformity grades; a major blocks certification until verified closed
OFI	Opportunity for improvement. Auditor advice; not a nonconformity
PDCA	Plan–Do–Check–Act
RC-01 to RC-06	Reconciliation conflicts between CGI-GAP-001 and the certification plan
RTP	Risk treatment plan (clause 6.1.3 e)
SAST	Static application security testing
SoA	Statement of Applicability (clause 6.1.3 d)
Stage 1 / Stage 2	Readiness review / implementation-and-effectiveness audit

Source documents

ID	Document	Version	Status
CGI-POL-001 to -005	Startup Security Policy Pack	1.0	Approved
CGI-RSK-001	Master Information Security Risk Register	1.1	14 risks after the CGI-TPR-001 merge
CGI-GAP-001	NIST CSF 2.0 Gap Assessment	1.0	Approved; GV.SC updated to 2 by CGI-TPR-001
CGI-TPR-001 / -002	Vendor Risk Programme / Questionnaire	1.0	Issued
CGI-ISO-001	**This document**	1.0	Draft for approval
ISO/IEC 27001:2022 + Amd 1:2024	Information security management systems — Requirements	2022	Referenced
ISO/IEC 27002:2022	Information security controls	2022	Referenced
ISO/IEC 17021-1 / 27006-1	Requirements for certification bodies	—	Referenced

End of CGI-ISO-001 v1.0. Prepared by O.S. For approval by Jerry Gold.